

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Clinical Health Record System Using

Multi-Layered Defence

A capstone Project

Presented to the Faculty of

The College of Information Technology Education

PHINMA University of Iloilo

In Partial Fulfilment

of the requirements for the degree

Bachelor of Science in Information Technology

By:

Aaron Vincent Adrid

Antonio Edward I J. Labios

Jhon Ronel Diocson

John Aries Sodusta

Kim Clarence B. Castro

Shaira Lancara

July 2026

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Table of Contents

Chapter I	3
Introduction	3
Background Of the Study	3
Statement of the Problem	8
Objective of the study	14
General Objective	14
Specific Objectives	15
Scope and Delimitation	18
Scope of the Study	18
Delimitation of the Study	19
Significance of the Study	21
For Healthcare Institutions and Clinic Operators	21
For Patients and the Public	22
For Information Systems and Computer Science Students	23
For Academic Researchers and Future Studies	24
For Healthcare Policy and Regulation in the Philippines	25
Definition of Terms	25
Chapter II	31
Review Related Literature	31
Electronic Health Records Systems	31
Healthcare Data Privacy	33
Healthcare Cybersecurity Threats and Challenges	34
Multi-Layered Defense Strategy	36
Related Studies and Research	38
Foreign Studies	38
Local Studies	39
Synthesis and Conclusion	40
REFERENCES	43
Firestore Authentication Services	61
Firestore Security Rules	62
Firestore Security Implementation Standards	63
Audit Logging and Firestore Integration	64
2.2 Level 1 Data Flow Diagram	82

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Chapter I

Introduction

Background Of the Study

The rapid advancement of digital technologies over the past two decades has profoundly reshaped operations across virtually every sector of society. Industries ranging from finance and education to government services and public health have increasingly adopted digital solutions to improve efficiency, accessibility, and the overall quality of service delivery. The widespread integration of information and communication technology into organizational processes has not only accelerated productivity but has also fundamentally altered the way data is collected, stored, processed, and shared across institutions.

The healthcare industry, in particular, has undergone a sweeping transformation as clinics, hospitals, and health facilities have gradually transitioned from paper-based systems to digital platforms for storing and managing patient information. This shift has been primarily driven by the growing need for faster, more accurate, and more accessible healthcare services that can meet the demands of an increasingly connected and technologically dependent world. Electronic health records, digital diagnostic tools, telemedicine platforms, and cloud-based data management systems have emerged as cornerstones of modern healthcare infrastructure, enabling healthcare providers to deliver more coordinated and efficient patient care.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

This digital transformation has resulted in major improvements in care coordination, diagnostic efficiency, and administrative streamlining. However, it has simultaneously opened new avenues for cybersecurity threats that pose serious risks to patient privacy and institutional integrity. Healthcare data is among the most sensitive categories of personal information, containing medical histories, laboratory results, prescriptions, financial records, and personal identification details. If compromised, such information can have devastating consequences for patients, healthcare providers, and the broader health system, including identity theft, insurance fraud, reputational damage, and life-threatening misdiagnoses arising from tampered medical records.

Despite the widespread adoption of digital technologies, a considerable number of healthcare organizations, particularly in developing regions, still rely on conventional paper-based record systems. These manual processes are inherently vulnerable to physical loss, accidental destruction, and unauthorized access, leaving sensitive patient data exposed to a wide range of risks. Even among healthcare providers that have transitioned to digital systems, many lack sufficient and up-to-date security frameworks capable of adequately protecting sensitive patient data from the rapidly evolving landscape of cyber threats, including ransomware attacks, phishing schemes, brute force intrusions, and sophisticated unauthorized data breaches.

The frequency and sophistication of cyberattacks targeting healthcare institutions have grown alarmingly in recent years. According to various international cybersecurity reports, the healthcare sector consistently ranks among the most targeted

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

industries globally, with data breaches resulting in significant financial losses, regulatory penalties, and long-term erosion of patient trust. Attackers are drawn to healthcare systems precisely because of the high value of medical data on illegal markets and the critical operational dependencies of health institutions, which often compel them to comply with ransom demands in order to restore access to vital patient information.

In the Philippine context, the digitization of health records remains in its early stages, and the majority of small to mid-sized clinics, rural health units, and private healthcare providers continue to lack the technical resources, trained personnel, and institutional frameworks necessary to implement robust security measures. This creates a critical and widening gap between the urgent need for secure digital health systems and the actual level of data protection currently in place across the country's healthcare landscape. The absence of strong cybersecurity infrastructure not only threatens individual patient privacy but also undermines the broader goals of national health information systems and the integrity of public health data.

Stronger and more reliable security measures are urgently needed to address these persistent challenges. One effective and widely recognized approach in the field of cybersecurity is Defense-in-Depth, a multi-layered security strategy that integrates several complementary protective mechanisms to collectively safeguard sensitive information. Rather than depending on a single line of defense, this approach operates on the principle that if one security layer is compromised or bypassed, additional layers remain in place to detect, contain,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

and prevent unauthorized access. This strategy has been endorsed by leading cybersecurity standards bodies and is increasingly regarded as a best practice for protecting sensitive digital assets across high-risk environments such as healthcare.

As Firebase Google's cloud-based backend platform becomes increasingly central to the development of modern web-based applications, including those used for storing and managing electronic health data, the need for robust, well-structured, and thoroughly tested security frameworks has become more urgent than ever before. Firebase offers flexible and scalable data storage solutions, but its effectiveness as a secure platform is highly dependent on the configuration of its security rules and the architectural decisions made during the development process. Inadequately secured Firebase implementations have been linked to significant data exposure incidents, highlighting the critical importance of applying comprehensive security controls when using this platform in healthcare-related systems.

This study aims to examine the challenges involved in protecting private health data stored in Firebase and to highlight the critical importance of adopting layered defense strategies in minimizing security vulnerabilities within healthcare environments. Specifically, this capstone project proposes the design and development of a Secure Clinical Health Record System Using Multi-Layered Defense a web-based electronic healthcare system purposefully designed and tailored to address the needs and limitations of small healthcare providers in the Philippines.

The proposed system integrates multiple security layers operating in concert to provide comprehensive protection for

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

electronic health records. These layers include pre-authentication protocols, manual authentication mechanisms, role-based access control (RBAC), audit logging, Firestore security rules, Cross-Origin Resource Sharing (CORS) filtering to restrict unauthorized external requests, fallback protection to prevent unauthorized users from reading or writing data, and continuous real-time monitoring. Together, these interconnected security components form a resilient and adaptive barrier against unauthorized access, data tampering, and potential data breaches.

By delivering both robust security and practical usability, this system seeks to empower small and underserved healthcare providers with enterprise-grade data protection capabilities that align with internationally recognized security standards, including those set forth by the Health Insurance Portability and Accountability Act (HIPAA) and relevant Philippine data privacy regulations under Republic Act No. 10173, also known as the Data Privacy Act of 2012. Ultimately, this capstone project aspires to contribute meaningfully to the ongoing effort to strengthen the cybersecurity posture of the Philippine healthcare sector and to demonstrate that effective, multi-layered security solutions can be designed and implemented even within the resource constraints typically faced by small healthcare institutions.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Statement of the Problem

The proliferation of cyber threats targeting healthcare information systems around the world has emerged as one of the most pressing challenges facing modern healthcare institutions. This escalating threat landscape is particularly pronounced when combined with the widespread reliance on insecure digital platforms or outdated paper-based record-keeping systems that continue to dominate the operational practices of small clinics, especially in developing and resource-limited healthcare settings. Together, these factors create a significant and continuously growing risk to patient data security, the continuity and integrity of institutional operations, and ultimately, the broader public trust in the healthcare system. The consequences of security breaches in healthcare environments extend far beyond mere data loss; they encompass potential threats to patient safety, violation of fundamental privacy rights, operational disruptions that can delay critical care, substantial financial losses due to recovery and remediation costs, and lasting reputational damage that can undermine community confidence in local healthcare providers.

Small clinics, in particular, face unique and especially challenging circumstances when it comes to cybersecurity. These institutions typically lack the financial resources, technical infrastructure, and specialized personnel necessary to implement comprehensive and sophisticated cybersecurity measures. Unlike large hospital systems and healthcare networks that can allocate dedicated budgets and hire full-time information technology specialists, small clinics must operate with minimal technological support and are forced to prioritize immediate

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

clinical and operational needs over long-term security investments. This resource constraint leaves small clinics, and the patients who depend on them, highly vulnerable to a diverse array of cyberattacks that could compromise the confidentiality of sensitive patient information, compromise the integrity of medical records, and disrupt the availability of critical healthcare services. The attackers targeting healthcare institutions recognize and actively exploit these resource limitations, making small clinics attractive targets precisely because their security defenses are known to be weaker than those of larger institutions.

The fundamental problem that this study seeks to address is the glaring absence of a secure, affordable, and operationally practical multi-layered digital health record system that has been specifically designed with the unique constraints and operational realities of small clinics in the Philippines in mind. While Electronic Health Record (EHR) systems certainly exist and have achieved widespread adoption in larger healthcare organizations, including major hospitals, healthcare networks, and government health facilities, these systems are typically engineered and marketed for institutions with substantially greater resources than what small clinics possess. These existing EHR solutions are characteristically resource-intensive in terms of both initial financial investment and ongoing operational costs, require sophisticated technical infrastructure and ongoing IT support, and demand a steep learning curve that necessitates extensive staff training. The complexity of implementation and configuration for existing systems often makes them entirely impractical for smaller clinical settings that operate on extremely limited budgets,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

employ only a handful of clinical staff with minimal technical expertise, and lack dedicated information technology resources or support personnel.

This significant gap in available solutions has created a deeply problematic situation in which patient data is either stored insecurely in poorly protected digital formats or remains entirely on paper and physical records. The paper-based approach, while familiar and operationally simple, exposes patient records to significant risks including accidental loss or destruction, unauthorized physical access and viewing by staff or visitors, environmental damage from water or fire, and the simple but serious problem of records becoming lost, misplaced, or disorganized. Conversely, when small clinics do attempt to digitize patient records, they typically lack the knowledge and resources to implement adequate security measures, resulting in systems with minimal encryption, weak or shared passwords, lack of access controls, no audit trails, and no backup or disaster recovery procedures. Both approaches are fundamentally insufficient and inadequate in the current threat landscape where cyberattacks are becoming increasingly frequent, sophisticated, and damaging.

Compounding this fundamental problem is the critical inadequacy of the security measures currently employed by many small healthcare clinics. The existing security practices commonly found in these institutions such as basic single-password login systems, shared user accounts that lack individual accountability, unencrypted local data storage on computers or external drives, minimal or completely absent access controls, and no mechanisms for recording or auditing who has accessed

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

patient information and when were designed for a far less threatening technological environment and are wholly inadequate against the sophisticated and continuously evolving tactics employed by modern cybercriminals. The cybersecurity landscape has fundamentally transformed in recent years, with attackers employing advanced techniques such as ransomware that can lock entire databases until payment is made, phishing attacks that trick staff into revealing credentials, brute force attacks that systematically test passwords, and zero-day exploits that target previously unknown vulnerabilities. A single compromised password, an unpatched software vulnerability, a successful phishing email, or an unsecured network connection is all that is needed to expose an entire database of sensitive patient records to malicious actors. The consequences extend far beyond the immediate loss of data they include serious violations of patient privacy, complete disruption of clinical operations, profound erosion of community trust and confidence, significant legal liability and regulatory penalties under the Data Privacy Act of 2012, and in the most serious cases, direct harm to patients whose medical records have been tampered with, corrupted, or rendered completely inaccessible at critical moments when their care depends on access to accurate and complete medical history.

The legal and regulatory dimensions of this problem further underscore the urgency of finding an effective and practical solution. Under Republic Act No. 10173, known as the Data Privacy Act of 2012, all entities in the Philippines that collect, process, store, or transmit personal information – a category that unquestionably includes all healthcare providers – are legally obligated to implement reasonable and appropriate

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

security measures proportionate to the sensitivity of the data under their custody. This legal obligation is not optional or discretionary; it represents a binding legal requirement backed by significant penalties for non-compliance. Small clinics that fail to adequately protect patient data face substantial legal exposure including financial penalties, court-ordered remediation costs, mandatory notifications to affected patients, loss of operational licenses, and significant reputational damage that can drive patients to seek care elsewhere. Beyond Philippine law, internationally recognized frameworks such as the Health Insurance Portability and Accountability Act (HIPAA) established in the United States establish comprehensive and globally-respected standards for the protection of health information that reflect the global professional consensus on what constitutes adequate and appropriate data security in healthcare settings. These frameworks provide clear guidance and best practices that can serve as models even for clinics operating in other jurisdictions.

It is in response to this critical situation of widespread vulnerability, unmet legal obligations, and institutional unpreparedness that this capstone study proposes the design and development of a Secure Clinical Health Record System that employs a comprehensive multi-layered Defense in Depth security strategy to protect electronic patient records managed through Firebase. The Defense in Depth approach, also known as security layering, is widely regarded by leading cybersecurity professionals, international standards organizations, and government cybersecurity agencies as one of the most effective and proven strategies for protecting sensitive digital assets in high-risk environments such as healthcare. This approach

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

operates on the foundational principle that security should not depend entirely on any single protective mechanism or control, but rather should integrate multiple independent and complementary layers of security controls so that if one layer is compromised or circumvented, other defensive layers remain in place to detect and prevent unauthorized access. By applying this battle-tested strategy within a system specifically engineered for the scale, budget, technical sophistication, and unique operational constraints of small Philippine clinics, this study seeks to demonstrate that enterprise-level and professional-grade data protection is not an exclusive privilege of large and well-resourced institutions but can and absolutely must be made accessible, affordable, and practically implementable for even the most resource-constrained healthcare providers.

In order to systematically investigate, analyze, and address the multifaceted problems and challenges described above, this study is guided and structured by the following carefully developed research questions that will direct the research methodology and evaluation framework:

1. How secure are the existing clinical health record systems currently used in small Philippine clinics, and what specific vulnerabilities do they present to unauthorized access, data manipulation, and data breaches?
2. Are the existing security measures commonly employed in healthcare systems used by small Philippine clinics – such

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

as basic password protection, shared user accounts, and traditional physical record-keeping – still effective and adequate in defending against the current and emerging landscape of cybersecurity threats?

3. How effective is a multi-layered Defense-in-Depth security strategy, as implemented in the proposed system, in protecting healthcare record systems against unauthorized access, data exfiltration, record manipulation, and system compromise, when compared to the conventional single-layer security approaches currently used in small clinical settings?
4. How can the proposed system effectively uphold and reinforce the three fundamental principles of the CIA triad – Confidentiality, Integrity, and Availability – of patient health records within the practical operational environment and constraints of a small clinical setting?
5. How does the proposed system improve and strengthen authentication mechanisms and access control procedures to effectively prevent unauthorized access attempts and to mitigate the risk of data breaches in a healthcare environment serving small clinics?

Objective of the study

General Objective

The primary and overarching objective of this study is to design, develop, and comprehensively evaluate a secure and user-friendly clinical health record management system specifically engineered for the operational context of small

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

private clinics. This system will employ a multi-layered defense strategy grounded in industry-recognized cybersecurity principles to effectively ensure the confidentiality, integrity, and availability of sensitive patient health data. By implementing this robust security framework, the proposed system aims to provide comprehensive protection against unauthorized access, data breaches, malicious system compromise, and other cybersecurity threats that are prevalent in the current and evolving healthcare threat landscape. Ultimately, this study seeks to demonstrate that small clinics, despite their limited resources, can and should have access to enterprise-grade data protection that meets or exceeds international standards for healthcare information security.

Specific Objectives

In pursuit of the general objective stated above, this study aims to accomplish the following specific objectives:

1. Develop a secure, web-based system for managing electronic health records that seamlessly integrates comprehensive and robust data protection features that are practical and implementable within the operational and resource constraints of small clinic environments.

This objective focuses on the core deliverable of the study – a functional, secure electronic health record system that is accessible through standard web browsers, requires minimal additional hardware investment, and can be realistically implemented and maintained by small clinic staff with varying levels of technical expertise.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

2. Implement a comprehensive multi-layered security architecture that encompasses multiple independent protective mechanisms including multi-factor authentication (MFA), advanced data encryption standards (AES-256 for data at rest and TLS for data in transit), granular role-based access control (RBAC), detailed audit logging capabilities, and continuous system monitoring to effectively restrict unauthorized access to sensitive patient records.

This objective emphasizes the technical implementation of the Defense-in-Depth security strategy, ensuring that patient data is protected through multiple, interconnected security controls that provide redundancy and defense in depth.

3. Rigorously evaluate and validate the effectiveness of the proposed security framework through comprehensive testing methodologies that assess its capability in preventing unauthorized access attempts, detecting anomalous and suspicious system activities, and successfully mitigating common healthcare-targeted cyberattacks including phishing campaigns, credential theft, brute force attacks, ransomware, and data exfiltration attempts.

This objective ensures that the security framework is not merely theoretically sound but has been systematically tested and validated to perform effectively against real-world threats in practical healthcare scenarios.

4. Ensure the preservation and protection of the three foundational principles of information security – Confidentiality, Integrity, and Availability (CIA triad) –

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

of all clinical health records through rigorously implemented technical safeguards, with effectiveness validated through structured security testing procedures and user acceptance testing with actual healthcare providers.

This objective affirms commitment to the internationally recognized security framework that ensures patient data remains private and secure (Confidentiality), unchanged by unauthorized parties (Integrity), and accessible to authorized users when needed (Availability).

5. Design and implement an accessible, intuitive, and user-friendly interface that enables healthcare providers and clinic staff to efficiently manage patient records while simultaneously maintaining strict security protocols and minimizing disruption to existing clinical workflows and staff productivity.

This objective recognizes that security alone is insufficient; the system must also be practical and usable by clinic staff, ensuring adoption and reducing the risk that staff will circumvent security measures due to poor usability or excessive complexity.

6. Comprehensively assess and evaluate the overall system performance across multiple critical dimensions including security robustness and resilience, user-interface usability and learnability, system reliability and uptime, data accuracy and consistency, and compliance with internationally recognized data protection standards and frameworks relevant to the Philippine healthcare context,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

including the Data Privacy Act of 2012 and HIPAA principles.

This final objective ensures that the system is evaluated holistically, not only on security measures but on all critical dimensions necessary for successful healthcare system deployment, ensuring that the system meets legal requirements and is ready for real-world clinical use.

Scope and Delimitation

Scope of the Study

This research study encompasses the design, development, and evaluation of a web-based clinical health record system specifically engineered for small private medical clinics in the Philippines. The system is designed to securely store, manage, retrieve, and maintain comprehensive patient health information while protecting the confidentiality and integrity of sensitive medical data. The system incorporates a multi-layered defense architecture consisting of multiple integrated protective layers, including advanced authentication mechanisms (single-factor and multi-factor authentication options), industry-standard encryption protocols for both stored data (AES-256) and data in transit (TLS), granular role-based access control (RBAC) that enforces principle of least privilege, comprehensive audit logging that records all system activities and data access, and real-time monitoring capabilities to detect suspicious activities.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The system is designed for accessibility and compatibility with the existing technology infrastructure of small clinics. It is accessible through standard web browsers (Chrome, Firefox, Safari, Edge) on any internet-enabled device (desktop computers, tablets, smartphones), ensuring broad compatibility without requiring costly hardware upgrades or specialized equipment. The responsive and mobile-friendly interface design, developed using modern web technologies (HTML, CSS, JavaScript), ensures that the system functions optimally across all device types and screen sizes, from desktop workstations in clinic offices to personal tablets used by healthcare providers during patient consultations.

The backend infrastructure is built on Google Firebase, selected as the primary database and application platform due to its proven scalability that can grow with clinic needs, real-time data synchronization capabilities that ensure all clinic devices have current patient information, robust built-in security features that provide an additional layer of protection, automated backup and disaster recovery capabilities, and cost-effectiveness that aligns with the budget constraints of small healthcare providers. The use of Firebase allows the system to leverage enterprise-grade cloud infrastructure without the burden of managing complex server systems on-site.

Delimitation of the Study

This research study has defined boundaries that clarify what the system does and does not include. Notably, this study does not encompass the development of advanced hospital-level functionality and integrations that are beyond the scope and

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

needs of small clinics. Specifically excluded are: integration with laboratory information systems (LIS) for automated lab result importation, integration with pharmacy management systems for prescription fulfillment, billing and insurance claim processing functionality, telemedicine and video consultation capabilities, artificial intelligence or machine learning-based diagnostic support systems, biometric authentication systems, and multi-branch or multi-facility healthcare network management capabilities.

The system is specifically designed and developed for small to medium-sized private clinics with patient populations typically ranging from a few hundred to several thousand patients. It is not designed to handle the large-scale patient volumes, complex departmental structures, and sophisticated operational workflows characteristic of large hospital systems. While the system is scalable, it is optimized for the typical operational size and complexity of small clinic environments.

An important technical limitation of the proposed system is that it requires a consistent and uninterrupted internet connection for optimal operation and data synchronization. The system is cloud-based and relies on connectivity to the Firebase platform for real-time data access, backup, and synchronization. Consequently, this system is best suited for clinics with reliable, stable, and continuous internet access. Clinics operating in areas with frequent internet outages or unreliable connectivity may experience functionality limitations, though the system does include some offline caching capabilities for essential functions during brief connectivity disruptions.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The evaluation and testing of the system is limited to the context of Philippine healthcare regulations, specifically the Data Privacy Act of 2012 (Republic Act 10173) and relevant Department of Health guidelines. While the system is designed to incorporate internationally recognized security standards (such as principles from HIPAA), specific compliance testing and validation is focused on Philippine regulatory requirements. Finally, this study does not include extended longitudinal evaluation in live clinical settings beyond the scope of user acceptance testing and system performance evaluation with a limited number of participating clinics.

Significance of the Study

This capstone study on designing and developing a Secure Clinical Health Record System Using Multi-Layered Defense for small clinics in the Philippines has profound and far-reaching significance across multiple stakeholder groups and contexts. The research addresses a critical and previously understudied gap in healthcare information security, the vulnerability of resource-limited small clinics that collectively serve millions of Filipinos but lack access to affordable, practical security solutions. The findings, deliverables, and recommendations from this research will have tangible impacts on healthcare security, patient safety, institutional operations, regulatory compliance, and academic knowledge in the field of healthcare cybersecurity.

For Healthcare Institutions and Clinic Operators

This study has direct and immediate practical value for small healthcare clinics, private medical practitioners, and clinic management organizations throughout the Philippines and

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

similar healthcare settings in developing countries. The proposed system provides a concrete, implementable, and affordable solution to the pervasive challenge of protecting sensitive patient data from unauthorized access, cyberattacks, and data breaches. By deploying this system, healthcare institutions can significantly reduce their vulnerability to cybersecurity threats that increasingly target healthcare providers, thereby protecting not only patient data but also the operational continuity and financial stability of their institutions.

Beyond security, the system provides numerous operational benefits to healthcare institutions. The web-based clinical health record system enables more efficient patient record management, reduces reliance on physical paper records with their associated risks of loss and disorganization, facilitates better care coordination among clinic staff, provides audit trails for quality assurance and accountability, and supports compliance with the Data Privacy Act of 2012 and other regulatory requirements. The system's design specifically considers the constraints of small clinics – limited budgets, minimal IT support, limited technical expertise among staff – making it more accessible and practical than generic enterprise solutions.

For Patients and the Public

Patients represent perhaps the most important beneficiary group for this research. The implementation of this secure health record system ensures meaningful protection of patient privacy and security of their sensitive medical information. Every Filipino patient deserves to have confidence that their

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

medical information – including their diagnoses, medications, medical histories, and personal health details – is protected from unauthorized access and misuse. Data breaches compromising patient information can lead to identity theft, insurance fraud, unauthorized disclosure of sensitive medical information, and other harms.

Beyond privacy protection, the system contributes to patient safety and improved quality of care. Accurate, secure, and readily accessible patient records enable healthcare providers to make better informed clinical decisions based on complete and current medical information. The integrity assurance provided by the system ensures that patient records have not been tampered with or corrupted, critical for safe and appropriate medical care. Additionally, the system's audit logging capabilities ensure accountability and create a record that can be used to investigate potential privacy violations or security incidents affecting patient data.

For Information Systems and Computer Science Students

This research project serves as a comprehensive reference and educational resource for Bachelor of Science in Information Technology (BSIT) students, computer science students, and aspiring cybersecurity professionals seeking to understand how to design and develop secure systems in practice. The project demonstrates the application of security principles and best practices in a real-world healthcare context, bridging the gap between theoretical knowledge learned in classrooms and practical implementation. Students can learn how to apply security design patterns, implement encryption, design

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

authentication systems, create audit logging mechanisms, and evaluate security effectiveness through testing.

Specifically, the study provides valuable insights into implementing the Defense-in-Depth security strategy, working with cloud-based backends like Firebase, integrating security controls into web application design, and conducting security testing and evaluation. The project source code, architecture documentation, security testing procedures, and user interface design can serve as reference materials for future student projects. Additionally, the study demonstrates how security can be integrated into usable system design – showing that strong security and good usability are not mutually exclusive but can and should be designed together.

For Academic Researchers and Future Studies

This research contributes significantly to the academic body of knowledge regarding healthcare information security, particularly in the context of resource-limited healthcare settings in developing countries. The study adds to the limited existing literature on cybersecurity solutions specifically designed for small healthcare providers, filling an important gap in healthcare information systems research. The findings regarding the effectiveness of multi-layered defense strategies in healthcare contexts, the usability of security-focused systems, and the unique vulnerabilities and constraints of small clinic settings will be valuable for other researchers working in healthcare security, health informatics, and related fields.

Future researchers can build upon this work by conducting extended longitudinal studies of the system in live clinical

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

settings, expanding the system to support additional healthcare functionalities, investigating the cost-benefit analysis of implementing such systems in small clinics, studying the adoption barriers and success factors for healthcare security systems in developing countries, or applying similar security design principles to other healthcare contexts or sensitive data management scenarios. The framework developed in this study can serve as a model for secure system design in other resource-limited institutional settings beyond healthcare.

For Healthcare Policy and Regulation in the Philippines

At the policy level, this research can inform the Department of Health, Philippine Health Insurance Corporation (PhilHealth), and other regulatory bodies regarding feasible and practical approaches to ensuring healthcare data security across the healthcare system, including small clinics. The system serves as a proof-of-concept that compliance with the Data Privacy Act of 2012 and international security standards is achievable even for small healthcare providers with limited resources. This research can support advocacy for healthcare security standards, inform guidelines for small clinic operations, and contribute to policy discussions about how to extend data protection assurances across the entire healthcare system, not just large institutional providers.

Definition of Terms

The following key terms and technical concepts are defined below to ensure clarity and mutual understanding throughout this research study. These definitions establish the precise meaning of terminology used in this thesis and are essential for

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

correctly interpreting the research findings, recommendations, and technical discussions.

Clinical Health Record (CHR) / Electronic Health Record (EHR) -

A comprehensive digital or paper-based collection of patient medical information maintained by a healthcare provider that documents the complete and current medical history, current health status, diagnoses, prescribed treatments, medication records, laboratory and imaging results, vaccination history, allergies and adverse reactions, surgical procedures, clinical encounter notes, and other health-related information. In the context of this study, a clinical health record serves as the authoritative and legally binding record of a patient's medical care and is essential for clinical decision-making, care continuity, quality assurance, and legal documentation of the patient-provider relationship.

Multi-Layered Defense (Defense-in-Depth) -

A comprehensive cybersecurity strategy and architectural approach that integrates multiple independent, redundant, and complementary layers of security controls, management practices, and protective mechanisms working in concert to safeguard sensitive information and systems. This approach operates on the foundational principle that no single security measure is completely impenetrable, and therefore multiple defensive layers should be implemented and maintained so that if one layer is compromised, breached, disabled, or fails, other protective layers remain functional to detect and prevent unauthorized access. In this study, multi-layered defense encompasses authentication mechanisms, encryption protocols, access control systems, monitoring and logging capabilities, and procedural controls.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Encryption - The mathematical and cryptographic process of converting readable and intelligible data (plaintext) into an unreadable, encoded, or scrambled format (ciphertext) using cryptographic algorithms and encryption keys to prevent unauthorized access and comprehension of sensitive information. Encryption serves two critical purposes in healthcare systems: encryption at rest (protecting stored data on servers and storage devices using standards such as AES-256) and encryption in transit (protecting data as it travels across networks using standards such as TLS 1.2). Only individuals possessing the correct decryption key can transform encrypted data back into its original readable form.

Role-Based Access Control (RBAC) - A method of managing and restricting access to data, system functions, and resources based on predefined user roles and associated permissions rather than granting permissions to individual users on a case-by-case basis. In healthcare systems, RBAC allows different categories of users (physicians, nurses, administrative staff, billing personnel, clinic managers) to have different levels of access to patient information appropriate to their specific job functions and responsibilities. RBAC implements the principle of least privilege, ensuring that users have access only to the minimum information necessary to perform their job responsibilities.

Confidentiality - The information security principle that ensures sensitive and personal data is accessible only to authorized individuals who have legitimate need and permission to view it, and is protected from unauthorized disclosure or access by unauthorized parties. In the healthcare context,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

confidentiality of patient health information is both an ethical obligation and a legal requirement under the Data Privacy Act of 2012. Breach of confidentiality through unauthorized disclosure of patient information can result in serious legal, financial, and reputational consequences.

Availability - The information security principle that ensures authorized systems and data are accessible and operational when needed by legitimate users to perform their job functions and provide patient care. In healthcare, availability is critical because interruptions in system access can delay essential patient care, compromise clinical decision-making, and potentially endanger patient safety. The healthcare industry typically requires high availability with minimal downtime to ensure that patient care is never compromised due to system unavailability.

Integrity - The information security principle that ensures data remains accurate, complete, unaltered, and unchanged except by authorized individuals performing authorized modifications. Data integrity means that patient health records have not been tampered with, corrupted, or modified by unauthorized parties. In healthcare, integrity is particularly critical because inaccurate or altered medical records could lead to incorrect diagnoses, inappropriate treatment decisions, and potential harm to patients.

Authentication -The process of verifying and confirming the identity of a user, device, or system before granting access to protected resources, data, or system functions. Authentication answers the critical question "Who are you?" and ensures that

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

individuals are who they claim to be before allowing access to sensitive patient information. Common authentication methods include single-factor authentication (username and password), multi-factor authentication requiring multiple independent proofs of identity, and digital certificates. In healthcare systems, strong authentication is essential.

Firestore - Google's comprehensive cloud-based backend-as-a-service (BaaS) platform that provides developers with integrated tools and services for building, deploying, and managing web and mobile applications without managing complex server infrastructure. Firestore includes real-time database services, cloud storage, user authentication, hosting, analytics, and monitoring. In this study, Firestore is selected as the backend platform because of its scalability, real-time data synchronization, built-in security features, automated backup and disaster recovery, cost-effectiveness, and ability to support small clinics without requiring on-site IT infrastructure.

Data Breach - An unauthorized access, disclosure, or loss of sensitive personal data that results from intentional or unintentional compromise of a computer system, network, or storage medium. In healthcare, a data breach involving patient health information is a serious incident with significant legal, financial, and ethical consequences. Data breaches can result from cyberattacks such as hacking or malware, insider threats, loss of devices containing unencrypted data, accidental misconfiguration of security settings, or physical theft of

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

equipment. Under the Data Privacy Act of 2012, healthcare organizations experiencing data breaches involving personal information are required to notify affected individuals.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Chapter II

Review Related Literature

This chapter presents a comprehensive review of existing scholarly literature, research, and theoretical frameworks related to the key topics and themes of this study. The literature review serves to establish the theoretical foundation, identify existing knowledge gaps, and position this research within the broader context of healthcare information security, cybersecurity practices, and health informatics. The following sections examine relevant topics including the evolution of healthcare information systems, cybersecurity threats in healthcare, data protection and privacy regulations, multi-layered defense strategies, cloud-based platforms for healthcare, and secure system design principles.

Electronic Health Records Systems

Electronic Health Records (EHRs) are digital versions of patient medical records designed to improve healthcare delivery through efficient information management and accessibility. EHR systems enable healthcare professionals to store, retrieve, update, and share patient information electronically across multiple healthcare settings. These systems have become essential components of modern healthcare because they enhance care coordination, reduce medical errors, improve clinical decision-making, and significantly improve overall healthcare accessibility and quality of care.

According to Tertulino, Antunes, and Morais (2024), EHR systems provide healthcare institutions with significant operational benefits by improving information availability and supporting

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

healthcare decision-making processes. Their systematic mapping study emphasized that EHR adoption has increased considerably due to advancements in information and communication technologies. The researchers noted that digital health records improve the quality of patient care while reducing operational costs and administrative burdens. However, they also highlighted that maintaining privacy and security remains a major challenge in EHR implementation, particularly as systems become more interconnected and handle increasingly larger volumes of sensitive patient information.

The digitization of healthcare information enables healthcare providers to access patient records in real-time, facilitating better communication and collaboration among medical professionals across different departments and locations. Electronic records improve record accuracy, reduce duplication of tests and procedures, support evidence-based clinical decisions, and enable more personalized patient care. Despite these substantial advantages, researchers have identified several serious concerns regarding unauthorized access, data breaches, privacy violations, and system vulnerabilities that may compromise patient trust, institutional integrity, and the overall effectiveness of healthcare delivery.

Healthcare organizations are increasingly adopting cloud-based infrastructures for storing and managing health records due to their scalability, cost efficiency, and remote accessibility features. Cloud technologies provide significant advantages including automatic scaling, reduced need for on-premises infrastructure, and built-in redundancy. However, cloud adoption also introduces additional security challenges, particularly

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

concerning data confidentiality, integrity, and availability. Therefore, healthcare institutions must implement comprehensive security controls and proper configuration management to ensure that patient information remains protected throughout its entire lifecycle, from initial collection through long-term storage and eventual secure deletion.

Healthcare Data Privacy

Privacy is one of the most important and critical considerations in healthcare information systems because patient records contain highly sensitive and personal information. Healthcare data may include personal identifiers such as names, addresses, and contact information; medical histories including diagnoses and past treatments; laboratory results; prescriptions and medication records; insurance information; diagnostic reports; and other sensitive health-related details. Unauthorized disclosure of such information may result in identity theft, discrimination, reputational harm, financial fraud, and serious legal consequences for both patients and healthcare institutions.

According to Tertulino et al. (2024) emphasized that preserving privacy within EHR systems is critical for maintaining public confidence in healthcare technologies and ensuring patient willingness to participate in digital healthcare initiatives. Their study identified privacy preservation as one of the primary research areas in healthcare information security. The researchers found that healthcare organizations continue to struggle with balancing accessibility and security, particularly in complex environments requiring frequent information sharing

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

among diverse healthcare professionals across multiple departments and settings.

Healthcare privacy concerns have become increasingly complex due to the emergence of big data analytics, cloud computing, artificial intelligence, and interconnected healthcare platforms that share information across institutions. Recent studies indicate that the widespread collection and analysis of health-related data increase the potential for privacy breaches and unauthorized information disclosure. Advanced security measures such as encryption, access control, anonymization, pseudonymization, and privacy-preserving technologies have therefore become necessary and essential components of modern healthcare systems.

Researchers have also noted that healthcare organizations must establish clear privacy policies, governance frameworks, and organizational procedures to regulate the collection, processing, retention, and sharing of patient information. Effective privacy management helps ensure compliance with legal requirements such as the Data Privacy Act of 2012 in the Philippines while protecting patient rights and maintaining organizational credibility and public trust.

Healthcare Cybersecurity Threats and Challenges

Cybersecurity refers to the protection of computer systems, networks, and digital information from unauthorized access, cyberattacks, and damage. In healthcare environments, cybersecurity plays a critical and essential role in safeguarding patient information, ensuring the integrity of medical data, and maintaining the availability and continuity of

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

uninterrupted healthcare services that patients depend on for their health and safety.

The healthcare sector has become one of the most frequently targeted industries for cyberattacks worldwide. According to Zlatolas, Welzer, and Lhotska (2024), healthcare digitalization has significantly increased the exposure of healthcare organizations to cyber threats and attack vectors. Their systematic review of ninety-nine peer-reviewed research studies revealed growing and escalating concerns regarding data breaches, ransomware attacks, phishing campaigns, insider threats, social engineering attacks, and unauthorized access incidents affecting healthcare institutions globally. The researchers found that the frequency and sophistication of these attacks are increasing at an alarming rate.

Healthcare data are particularly valuable targets for cybercriminals because they contain comprehensive personal information that can be exploited for financial gain, identity theft, insurance fraud, and blackmail. Medical records contain not only health information but also personal identifiers, financial details, and insurance information that criminals can monetize on the dark web or use for identity theft. As a result, cybercriminals increasingly target healthcare databases and information systems. Researchers observed that healthcare organizations often face significant challenges in implementing adequate cybersecurity measures due to limited financial resources, outdated and legacy technologies, inadequate security infrastructure, and insufficient security awareness and training among healthcare staff.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Recent healthcare cybersecurity incidents demonstrate the severe and devastating consequences of inadequate security controls. Large-scale healthcare breaches have exposed millions of patient records and disrupted critical healthcare services worldwide, leading to financial losses, loss of patient trust, and in some cases, harm to patients who could not access their medical information or receive timely care. Reports from cybersecurity organizations indicate that most healthcare breaches are caused by hacking and information technology-related incidents, highlighting the urgent and critical need for stronger, more comprehensive security frameworks that address emerging and evolving threats.

Multi-Layered Defense Strategy

Multi-layered defense, also known as defense-in-depth, is a comprehensive cybersecurity strategy that utilizes multiple independent security controls and protective mechanisms working in concert to protect information systems and data. Instead of relying on a single protective mechanism or control, defense-in-depth establishes several independent and complementary layers of security that collectively and significantly reduce the likelihood of successful attacks. This approach is based on the understanding that no single security control is completely impenetrable and that multiple defensive layers provide superior protection through redundancy.

According to Zlatolas et al. (2024) explained that healthcare systems require comprehensive and layered protection due to the complexity of modern cyber threats and attack vectors. Their systematic review identified numerous security mechanisms used in healthcare environments, including encryption for protecting

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

data confidentiality, access control for restricting unauthorized access, authentication for verifying user identity, intrusion detection systems for identifying attacks, and continuous monitoring systems for detecting suspicious activities. The researchers emphasized that layered security architectures significantly improve organizational resilience by ensuring that if one security layer is compromised or bypassed, additional defenses remain operational to prevent complete system compromise.

A comprehensive multi-layered defense framework typically includes preventive, detective, and corrective controls. Preventive controls aim to stop attacks before they can occur or compromise systems; detective controls identify suspicious activities and potential security incidents in real-time or shortly after occurrence; and corrective controls facilitate incident response, containment, and recovery from security incidents. The integration and coordination of these control types creates a comprehensive security environment capable of addressing diverse threat scenarios and attack methods.

For small healthcare facilities with limited resources and budgets, defense-in-depth offers a practical and scalable approach to cybersecurity that does not require expensive enterprise-level infrastructure. By systematically combining multiple security mechanisms, small organizations can progressively strengthen protection and resilience without proportional increases in costs. This strategy aligns closely with the objectives and principles of the proposed Secure Clinical Health Record System Using Multi-Layered Defense, which

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

is specifically designed for the resource constraints of small clinics.

Related Studies and Research

Foreign Studies

According Tertulino et al. (2024) conducted a systematic mapping study examining privacy requirements in Electronic Health Record systems. Their research analyzed existing literature concerning security and privacy requirements in EHR environments across multiple countries and healthcare contexts. The study concluded that privacy preservation remains one of the most significant challenges in healthcare information systems and recommended stronger access controls, robust authentication mechanisms, and encryption technologies to address these critical concerns.

Zlatolas et al. (2024) performed a comprehensive systematic review of healthcare data breach mitigation strategies. Their analysis of ninety-nine peer-reviewed research papers identified encryption, blockchain technologies, artificial intelligence, and access control mechanisms as effective approaches for reducing healthcare cybersecurity risks. The researchers emphasized that multi-layered security frameworks provide significantly stronger protection against emerging and evolving cyber threats compared to single-point security solutions.

According to waya, Ahmad, and Babar (2020) investigated security and privacy issues in mobile and ubiquitous healthcare systems. Their comprehensive study reviewed 365 research publications and found that authentication, authorization, access control, and privacy management are among the most critical security requirements in healthcare technologies. They further

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

recommended comprehensive security governance frameworks and organizational policies to address evolving threats in healthcare environments.

According to Herath et al. (2024) proposed an attacker-centric security model specifically designed for virtual healthcare environments. Their research examined healthcare security breaches occurring between 2009 and 2023 and developed a multi-layered threat mitigation framework based on analysis of actual attack patterns and breach methodologies. The findings demonstrated that proactive threat modeling and layered security controls significantly improve healthcare cybersecurity resilience and reduce the likelihood of successful attacks.

Tariq, Ahmed, Khan, and Kim (2023) conducted a comprehensive survey of healthcare cybersecurity challenges and solutions. Their research analyzed emerging threats, existing defense mechanisms, and best practices across healthcare organizations globally. The study provided recommendations for implementing robust cybersecurity frameworks and highlighted the importance of continuous monitoring and regular security assessments in healthcare environments.

Local Studies

In the Philippines, healthcare digitalization continues to expand due to government initiatives and policies promoting the adoption of electronic health information systems. Local studies emphasize the importance of cybersecurity and privacy protection in healthcare applications because healthcare providers increasingly rely on digital technologies to store, manage, and share patient information. Healthcare digitalization efforts are

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

particularly important in the Philippine context where many rural and community health centers lack access to advanced healthcare technologies.

Research conducted in Philippine healthcare settings consistently highlights challenges related to limited cybersecurity resources, inadequate security awareness among healthcare staff, and insufficient implementation of comprehensive security controls. Local researchers and practitioners recommend adopting and implementing role-based access control mechanisms, strong encryption technologies, and multi-factor user authentication systems to improve healthcare information security. These recommendations are consistent with international best practices and standards for healthcare information protection.

Studies concerning the implementation of the Philippine Data Privacy Act of 2012 (Republic Act 10173) consistently emphasize the legal responsibility of healthcare institutions to protect personal information through appropriate organizational, physical, and technical safeguards. Healthcare organizations must therefore establish comprehensive information security programs and governance frameworks that ensure the confidentiality, integrity, and availability of patient data. Compliance with this regulatory requirement is both a legal obligation and an ethical responsibility to patients.

Synthesis and Conclusion

The reviewed literature and research studies consistently demonstrate the growing importance and urgency of cybersecurity within healthcare environments. Electronic Health Record systems

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

have significantly improved healthcare service delivery, enhanced care quality, and increased operational efficiency. However, the widespread adoption of digital healthcare systems has also increased exposure to cyber threats and vulnerabilities. Researchers across international and local contexts agree that healthcare organizations must implement strong, comprehensive, and layered security mechanisms to effectively protect sensitive patient information from unauthorized access, data breaches, and sophisticated cyberattacks.

The studies reviewed in this chapter reveal that authentication mechanisms, encryption technologies, access control systems, audit logging, and continuous monitoring are among the most effective and widely recommended security controls for healthcare systems. Additionally, substantial evidence suggests that multi-layered defense strategies provide superior protection and resilience compared to conventional single-layer security approaches because they establish multiple independent barriers against potential attackers and reduce the risk of complete system compromise.

The reviewed literature strongly supports the development and implementation of the proposed Secure Clinical Health Record System Using Multi-Layered Defense. Specifically, the research findings and recommendations justify the inclusion of role-based access control, multi-factor authentication mechanisms, advanced encryption technologies, comprehensive audit logging, and continuous real-time monitoring as core and essential security components of the proposed system. Furthermore, the literature identifies a critical gap: the need for healthcare security

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

solutions specifically designed for small clinics with limited resources in the Philippine context, a gap that this research study aims to address through the development of an affordable, practical, and effective secure health record system.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

REFERENCES

Alsubaei, F., Abuhussein, A., & Shiva, S. (2019). Security and privacy in the Internet of Medical Things: Taxonomy and risk assessment. *IEEE Consumer Electronics Magazine*, 8(6), 37-45.

Department of Health. (2023). Philippine Health Information Exchange framework. Government of the Philippines.

Herath, H., Perera, I., & Silva, N. (2024). Attacker-centric security framework for healthcare information systems. *International Journal of Information Security*, 23(4), 851-870.

Hossain, E., Rana, R., Higgins, N., Soar, J., Barua, P. D., Pisani, A. R., & Turner, K. (2023). Natural language processing in electronic health records in relation to healthcare decision-making: A systematic review. *Computers in Biology and Medicine*, 155, 106649.
<https://doi.org/10.1016/j.combiomed.2023.106649>

Iwaya, L. H., Ahmad, A., & Babar, M. A. (2020). Security and privacy for mobile and ubiquitous healthcare systems: A systematic mapping study. *IEEE Access*, 8, 150335-150352.

Keshta, I., & Odeh, A. (2023). Integrated personal health record security: Requirements and mechanisms. *BMC Medical Informatics and Decision Making*, 23(116).

McLeod, A., & Dolezel, D. (2018). Cyber-analytics: Modeling factors associated with healthcare data breaches. *Decision Support Systems*, 108, 57-68.

National Privacy Commission. (2023). Implementing rules and regulations of the Data Privacy Act of 2012. Government of the Philippines.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Republic of the Philippines. (2012). Republic Act No. 10173: Data Privacy Act of 2012. Official Gazette.

Sim, J. A., Huang, X., Horan, M. R., Stewart, C. M., Robison, L. L., Hudson, M. M., Baker, J. N., & Huang, I. C. (2023). Natural language processing with machine learning methods to analyze unstructured patient-reported outcomes derived from electronic health records: A systematic review. *Artificial Intelligence in Medicine*, 146, 102701.

Tariq, U., Ahmed, M., Khan, M. A., & Kim, Y. S. (2023). A comprehensive survey of healthcare cybersecurity challenges and solutions. *IEEE Access*, 11, 58412-58439.

Tertulino, R., Antunes, N., & Morais, H. (2024). Privacy in electronic health records: A systematic mapping study. *Journal of Public Health*, 32(3), 435-454.
<https://doi.org/10.1007/s10389-022-01795-z>

Zlatolas, L., Welzer, T., & Lhotska, L. (2024). Data breaches in healthcare: Security mechanisms for attack mitigation. *Cluster Computing*. <https://doi.org/10.1007/s10586-024-04507-2>

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Chapter III

Methodology

Research Design

This study will employ a Developmental Research Design, a systematic and rigorous research methodology that focuses on the design, development, implementation, and comprehensive evaluation of technological systems, products, or solutions intended to address specific and identifiable problems or organizational needs. Developmental research represents a distinct research paradigm that integrates both design science and empirical investigation, providing a framework that is particularly suitable for information technology projects in specialized domains such as healthcare.

Developmental research methodology is particularly appropriate for this study due to several compelling factors. The primary objective extends beyond merely investigating existing problems related to healthcare record security; it encompasses the creation, implementation, and thorough assessment of a functional, secure healthcare record management system that provides evidence-based solutions to identified vulnerabilities and cybersecurity threats. This dual focus on both problem identification and solution development is a hallmark of developmental research approaches.

Specifically, the research will involve the comprehensive design and development of a secure healthcare record management system tailored for small-to-medium sized clinics operating throughout the Philippines. The proposed system will integrate a multi-layered defense strategy incorporating contemporary

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

cybersecurity principles to substantially enhance the security posture of electronic health records and provide robust protection of sensitive patient information against unauthorized access, data breaches, exfiltration, and other evolving cybersecurity threats. Through this comprehensive approach, the study aims to address the critical security limitations commonly identified in existing record management practices and infrastructure within small healthcare facilities throughout the region.

The developmental process will consist of seven distinct and sequential phases: (1) requirements analysis and gathering, (2) system planning and specification, (3) system architecture and design, (4) system development and implementation, (5) comprehensive testing and quality assurance, (6) system deployment and integration, and (7) post-implementation evaluation and performance assessment.

During the initial requirements gathering phase, comprehensive information regarding existing healthcare record management practices, identified security vulnerabilities, current infrastructure limitations, and detailed user requirements will be systematically collected from relevant stakeholders including clinic administrators, healthcare practitioners, IT personnel, and patient representatives.

The planning and design phases will focus on identifying and specifying appropriate security mechanisms, architectural patterns, and system features that comprehensively support the fundamental security principles of confidentiality, integrity, and availability of patient health records. This phase will incorporate threat modeling, security architecture definition,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

and risk assessment methodologies to ensure robust security design.

The development phase will involve the actual construction and implementation of the proposed healthcare record management system utilizing contemporary software development tools, industry-standard programming languages, modern database technologies, and established security frameworks and best practices. The system will incorporate multiple layers of security features including secure user authentication mechanisms, role-based access control (RBAC) systems, advanced data encryption protocols, comprehensive audit logging capabilities, automated backup mechanisms, disaster recovery procedures, and additional protective measures specifically designed to strengthen healthcare information security.

Following development completion, the system will undergo extensive and rigorous testing to evaluate its functionality, reliability, usability, performance characteristics, and security effectiveness. Testing procedures may include functional testing, security testing (including vulnerability assessment and penetration testing), user acceptance testing, and comprehensive performance evaluation to determine whether the system meets its intended objectives, security requirements, and functional specifications. Any identified issues, vulnerabilities, or performance concerns will be systematically addressed through iterative revisions and improvements before final evaluation and deployment.

The evaluation phase will critically assess the effectiveness of the proposed system in protecting healthcare records, maintaining information security principles, and supporting

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

clinical workflows. Comprehensive feedback will be gathered from potential users, healthcare personnel, information security experts, and information technology professionals to determine the system's usability, security effectiveness, practical applicability, and overall acceptability within a small clinical environment.

By employing this developmental research design, this study will contribute substantially to the scientific understanding of healthcare information security challenges and practical implementation barriers while simultaneously providing a practical, secure, cost-effective, and sustainable solution specifically tailored to the operational needs of small clinics. The findings and artifacts of the study are expected to demonstrate empirically how a comprehensive multi-layered security approach can significantly improve healthcare record management, strengthen the protection of sensitive patient information against evolving cyber threats, and enhance overall system reliability and usability.

System Development Methodology

This study will utilize the Agile Development Model as the primary system development methodology for designing and implementing the proposed secure healthcare record management system. The Agile methodology represents a flexible and iterative software development approach that emphasizes continuous improvement, cross-functional collaboration, rapid and incremental development cycles, and regular feedback integration from stakeholders throughout the entire development process.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Unlike traditional software development methodologies that follow rigid, predetermined sequences of activities with limited opportunity for modification (such as the Waterfall model), Agile permits developers to make systematic adjustments, incorporate improvements, and respond to identified issues as the project progresses. This adaptive approach ensures that the final system effectively and comprehensively meets user requirements, security objectives, and evolving organizational needs.

The Agile Development Model is particularly suitable for this study for several well-established reasons. The proposed healthcare record management system requires continuous evaluation, testing, and refinement to ensure that its features, functionality, and security mechanisms effectively and comprehensively address the specific needs of small clinics while maintaining alignment with healthcare regulatory requirements. Through iterative development cycles involving multiple sprint periods, the system can be systematically and incrementally improved based on comprehensive testing results, direct user feedback, and newly identified security concerns or operational requirements.

This iterative approach provides several distinct advantages: it enables early detection and resolution of security vulnerabilities, facilitates rapid integration of user feedback, supports progressive feature delivery, and ensures continuous quality assurance. This methodology helps ensure that the final product is robust, user-friendly, operationally reliable, and comprehensively capable of protecting sensitive patient information from potential and evolving cybersecurity threats.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The Agile Development Model implementation for this study comprises the following five primary stages:

Stage 1: Requirements Analysis and Definition

The initial stage involves comprehensive gathering, analysis, and documentation of functional and non-functional requirements necessary for the development of the proposed secure healthcare record management system. Detailed information will be systematically collected regarding current record management practices, identified security vulnerabilities and challenges, operational workflows, and specific needs and pain points of small clinics.

The research team will conduct stakeholder interviews, analyze existing systems, perform gap analysis, and document the functional requirements of the system, including user management, patient record storage and retrieval, data security specifications, authentication mechanisms, access control policies, data backup and recovery procedures, compliance requirements, and reporting functionalities.

During this phase, the research team will also conduct comprehensive threat modeling and vulnerability assessment to identify specific cybersecurity risks associated with existing healthcare record systems and determine the security features and defensive mechanisms required to effectively address these identified vulnerabilities and threats. The gathered and analyzed requirements will serve as the foundational specification for the subsequent design and development phases.

Stage 2: System Design and Architecture

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The design stage focuses on creating the comprehensive overall architecture, logical structure, detailed specifications, and implementation blueprint of the proposed system. Based on the identified and prioritized requirements, the research team will develop detailed system models, process flow diagrams, database design specifications, user interface layouts and wireframes, and comprehensive security frameworks.

The design will precisely define how different components and modules of the system interact with one another, how patient information will be securely stored, processed, accessed, and transmitted throughout the system. Security measures including role-based access control (RBAC), password encryption and hashing, multi-factor authentication (MFA), audit trails and logging mechanisms, data backup mechanisms, database security controls, and network security specifications will be comprehensively incorporated into the system design.

This phase ensures that both functional requirements and comprehensive security requirements are properly integrated, validated, and thoroughly documented before actual development implementation begins.

Stage 3: System Development and Implementation

The development stage involves the actual construction, coding, and implementation of the healthcare record management system. Utilizing appropriate and industry-standard programming languages, frameworks, libraries, and database technologies, the research team will implement the system based on the detailed specifications and architectural design established during the design phase.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Core functionalities including patient registration and demographic management, comprehensive electronic health record management, appointment tracking and scheduling, user account management, authentication processes, access control enforcement, data validation, notification systems, and extensive security controls will be systematically implemented. Additionally, the multi-layered defense mechanisms proposed by the study will be progressively integrated into the system to provide enhanced, comprehensive protection against unauthorized access, data breaches, malware attacks, and other cybersecurity threats.

Throughout this stage, Agile principles support incremental and modular development, enabling individual features and security components to be developed, tested, integrated, and improved continuously in iterative cycles. This approach allows for early identification and resolution of integration issues and technical challenges.

Stage 4: Comprehensive Testing and Quality Assurance

After development of system components and features, the system will undergo comprehensive, multi-level testing to ensure that all functionalities operate correctly, securely, and reliably, and that security mechanisms perform as intended under normal and edge-case conditions. Multiple testing methods and techniques will be systematically conducted to identify errors, vulnerabilities, performance issues, and other factors that may adversely affect the system's effectiveness, security, and reliability.

Functional testing will verify whether the system's features meet the specified functional requirements and operate

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

correctly. Security testing will conduct rigorous evaluation of the effectiveness of authentication controls, access restrictions, encryption mechanisms, data transmission security, and other protective measures. Performance testing will assess system responsiveness, reliability, and stability under different usage conditions, load levels, and stress scenarios.

Any issues, vulnerabilities, or deficiencies identified during testing will be documented in detail and systematically addressed through system modifications, code corrections, and improvements. This iterative testing and improvement process is central to the Agile methodology's objective of continuous enhancement and comprehensive quality assurance.

Stage 5: System Review, Evaluation, and Refinement

The final stage comprises the comprehensive review phase, where the completed system will be critically evaluated to determine its overall effectiveness, usability, operational performance, and security capabilities. Detailed feedback will be systematically gathered from potential users, healthcare personnel, information security professionals, and information technology experts regarding the system's functionality, user experience, practical applicability, and demonstrated ability to protect sensitive patient information.

The research team will conduct comprehensive analysis of the evaluation results to determine whether the proposed system successfully achieves its stated objectives of substantially enhancing healthcare record security and maintaining the fundamental security principles of confidentiality, integrity, and availability of patient data. Recommendations for identified

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

future improvements and potential system enhancements will be documented and analyzed during this concluding phase.

Through comprehensive implementation of the Agile Development Model, the study aims to develop a secure, reliable, user-centered, and operationally practical healthcare record management system that effectively addresses the significant cybersecurity challenges faced by small clinics while providing a practical, sustainable, and scalable solution for securely managing electronic health records.

System Architecture and Design

The proposed healthcare record management system will utilize a Client-Server Architecture model, a widely adopted and proven architectural pattern that enables efficient asynchronous communication between end-user clients and a centralized server responsible for processing requests, managing data, enforcing security controls, and maintaining system state and integrity. This distributed computing architecture is particularly suitable for healthcare information systems because it provides centralized data management, enhanced security control, simplified maintenance and updates, controlled access to sensitive patient information, and improved system scalability.

In the proposed system, authorized users such as clinic administrators, physicians, nurses, medical technicians, and other healthcare personnel will interact with the system through a web-based client interface accessible within the clinic's secure network infrastructure. The client side functions as the presentation layer, providing the graphical user interface (GUI) through which healthcare personnel perform various clinical and administrative tasks such as patient registration, medical

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

record management, appointment scheduling, record retrieval, report generation, and system administration functions. Through an intuitive, responsive, and user-friendly interface, healthcare personnel can efficiently access the clinical information necessary to support patient care operations and clinical decision-making.

The server component functions as the central processing unit and logic layer of the system, responsible for receiving, validating, and processing user requests, executing business logic, enforcing authentication and authorization policies, managing data transactions, and communicating with the database layer. Whenever an authorized user submits information or requests access to patient records, the server immediately validates the user's credentials, verifies their authentication status, checks their assigned permissions and access rights, and only then grants or denies access accordingly. This centralized control mechanism provides robust assurance that only authorized personnel with appropriate role-based permissions can view, modify, create, or manage sensitive healthcare information.

The database server serves as the persistent storage layer of the architecture and maintains comprehensive storage of all patient health records, user account information, audit logs and activity records, appointment data, system configuration parameters, and all other relevant healthcare and operational information. To enhance data security and privacy protection, sensitive information stored within the database will be protected using advanced encryption techniques such as Advanced Encryption Standard (AES) with strong key management. Encryption transforms data into cryptographically secure formats that can

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

only be accessed and interpreted by authorized users possessing the appropriate decryption credentials and keys. This security measure provides substantial protection of patient records from unauthorized access, data theft, information leakage, and other privacy violations even in the event of a database security breach or physical theft of storage media.

The client-server architecture provides ideal support for implementation of the study's proposed comprehensive multi-layered defense strategy. Security controls are enforced at multiple distinct levels of the system: user authentication and credential validation occur at the client interaction level, comprehensive access control and request validation occur at the server processing level, and encryption, data protection, and backup mechanisms occur at the database storage level. This layered, defense-in-depth approach significantly strengthens the overall security posture and resilience of the healthcare record management system by providing multiple independent barriers and security controls against potential cyber threats and attacks.

Furthermore, the architecture will incorporate Role-Based Access Control (RBAC) mechanisms to systematically regulate user permissions and access rights according to specific job responsibilities, professional roles, and organizational requirements. Different user roles, such as system administrators, physicians, nurses, medical technicians, receptionists, and billing personnel, will be assigned varying levels of access to patient information, system functionalities, and administrative capabilities. This granular access control ensures that users can only access specific information and features necessary for their assigned duties, thereby minimizing

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

the risk of unauthorized disclosure, modification, or misuse of sensitive records.

To maintain data integrity and ensure availability of critical information, the system will include comprehensive mechanisms such as comprehensive audit logging, transaction validation and rollback capabilities, automated backup procedures, disaster recovery planning, and recovery mechanisms. Detailed audit logs will record all user activities, system events, data modifications, access attempts, and security-related events, allowing system administrators to monitor access patterns, investigate potential security incidents, and ensure regulatory compliance. Automated backup and recovery features will help ensure that patient information remains consistently accessible and recoverable in the event of hardware failures, software malfunctions, accidental data deletions, cyberattacks, or natural disasters.

The client-server model provides additional advantages in scalability and maintainability. System updates, security patches, database schema modifications, and application updates can be managed and deployed centrally through the server infrastructure without requiring extensive changes, redistribution, or updates on individual client devices. This architecture simplifies system administration tasks, reduces deployment complexity, improves change management processes, and allows future enhancements and improvements to be implemented more efficiently as the operational needs of the clinic evolve and change.

The proposed architecture will also incorporate network security measures including secure communication protocols (HTTPS/TLS),

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

firewalls, intrusion detection systems, and network segmentation to provide additional layers of protection against external threats and unauthorized network access attempts.

Overall, the Client-Server Architecture provides a secure, reliable, maintainable, and scalable framework for the proposed healthcare record management system. By combining centralized data management, encrypted data storage, granular access control mechanisms, comprehensive audit capabilities, and multi-layered security controls, the architecture systematically supports the study's primary objective of protecting sensitive patient information while ensuring efficient, reliable, and user-friendly healthcare record management within small clinical environments.

Tools and Technologies Used

The development of the proposed Secure Healthcare Record Management System will utilize comprehensive, industry-standard software tools and contemporary technologies to ensure efficient system development, reliable performance, enhanced security, and maintainability. These technologies were carefully selected based on their proven compatibility, ease of implementation, scalability potential, open-source or cost-effectiveness for small organizations, support community strength, and demonstrated ability to support comprehensive security requirements of healthcare information systems.

Frontend Technologies and User Interface Development

The frontend components of the system will be developed using HTML (HyperText Markup Language) and CSS (Cascading Style Sheets). These foundational web technologies will be responsible

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

for creating the responsive graphical user interface (GUI) through which healthcare personnel interact with and access the system.

HTML will be used to structure web pages, forms, input fields, tables, data displays, navigation menus, buttons, and other interface components according to semantic markup standards. It provides the fundamental structure and content framework for displaying clinical information and collecting user input within the healthcare record management system.

CSS will be utilized to substantially enhance the appearance, layout, and usability of the system by controlling the visual styling, colors, typography, spacing, responsive design breakpoints, animations, and overall responsiveness of the user interface across different devices and screen sizes. Through CSS, the system will provide a clean, organized, modern, and user-friendly design that improves the overall user experience and efficiency for clinic staff members with varying levels of technical expertise.

The combination of HTML and CSS, potentially augmented with JavaScript frameworks, will enable the development of an accessible, responsive, and cross-browser compatible web-based interface that can be used efficiently and effectively by authorized healthcare personnel within the clinic environment and on various devices.

Backend Logic and Application Programming

The backend functionality and business logic of the system will be developed using JavaScript (JS), particularly modern JavaScript (ES6+) standards. JavaScript will serve as the

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

primary and versatile programming language responsible for handling system logic, processing user requests, validating user input, managing interactions with the database, implementing core system functionalities, and orchestrating communication between frontend and backend components.

JavaScript enables the development of dynamic and interactive web applications, making it well-suited for healthcare record management systems that require real-time data processing, immediate user interaction feedback, and responsive user interfaces. JavaScript will facilitate critical operations including patient record creation and initialization, updating and modification of patient information, user authentication and session management processes, appointment management and scheduling, retrieval of healthcare records and patient data, and generation of system reports.

Additionally, JavaScript will support secure asynchronous communication between the frontend user interface and the database through standardized Application Programming Interfaces (APIs) and cloud database services, allowing seamless, real-time data exchange and synchronization within the system.

Security and Authentication Technologies

To substantially strengthen the security of patient health records and user accounts against contemporary cyber threats, the system will utilize advanced security services and authentication technologies, specifically leveraging Firebase's comprehensive security infrastructure. Firebase provides enterprise-grade security tools specifically designed for healthcare and sensitive data applications.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Firestore Authentication Services

Firestore Authentication will be implemented as the primary authentication service to provide secure user login, identity verification, session management, and comprehensive account access controls. This service ensures robust authentication mechanisms such that only authorized healthcare personnel can access the system.

Firestore Authentication will support multiple authentication mechanisms including:

- Email and password verification with enforced strong password policies requiring minimum length, complexity, and character diversity
- Secure session management with configurable automatic timeout periods to prevent unauthorized access from unattended sessions
- Multi-factor authentication (MFA) for sensitive operations, including SMS-based verification codes, authenticator apps (Google Authenticator, Microsoft Authenticator), and email verification
- Comprehensive account access controls including account lockout policies after multiple failed login attempts
- Password reset and account recovery mechanisms with secure verification processes
- User account provisioning and deprovisioning workflows for staff onboarding and offboarding
- Session token management with secure token refresh mechanisms and expiration policies

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Firebase Authentication integrates seamlessly with the web-based application, providing client-side authentication libraries (Firebase SDKs) that handle authentication workflows securely without exposing credentials to the application backend in plaintext.

Firebase Security Rules

Firebase Security Rules will be configured at the database level to enforce granular, role-based restrictions on unauthorized access to sensitive healthcare information stored in the Firebase Realtime Database or Firestore. These declarative security rules precisely define and enforce which authenticated users can read, write, modify, or delete specific data based on their assigned roles, organizational permissions, and security clearance levels.

Specific Firebase Security Rules implementations will include:

- **Role-Based Access Control (RBAC) Rules:** Security rules will evaluate user roles (administrator, physician, nurse, receptionist, etc.) and grant or deny access to specific patient records, administrative functions, and system data based on role definitions
- **Data-Level Access Restrictions:** Rules will restrict access at the collection and document level, ensuring that users can only access patient records they are authorized to view based on clinic assignments and specialty areas
- **User-Specific Permissions:** Rules will verify authenticated user identity (auth.uid) and compare against permission matrices stored in the database to determine read/write/delete permissions

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- **Timestamp-Based Access Controls:** Rules can enforce time-based access restrictions, limiting access to records during specific operational hours or restricting access to archived records
- **Validation Rules:** Security rules will validate data structure, field types, and content before allowing write operations, preventing invalid or malicious data insertion

Example security rule structure:

- Allow authenticated users to read only their own records or records within their assigned clinic
- Allow physicians to read and write patient records in their clinic
- Allow nurses to read patient records and write clinical notes
- Allow administrators full access to manage users and system settings
- Deny all other access attempts

Firebase Security Implementation Standards

The Firebase security implementation will follow healthcare security best practices:

- **Encryption in Transit:** All data transmitted between clients and Firebase servers will be automatically encrypted using HTTPS/TLS 1.2 or higher, ensuring that data cannot be intercepted or viewed during transmission
- **Encryption at Rest:** Firebase automatically encrypts all data stored in the database at rest using AES-256

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

encryption, protecting data from unauthorized access even if storage media is physically compromised

- **Authentication Token Security:** Firebase generates secure, short-lived authentication tokens (JSON Web Tokens - JWTs) that expire within a configurable period, minimizing the impact of token compromise
- **Secure Credential Storage:** Firebase SDKs securely store authentication credentials on client devices using platform-specific secure storage mechanisms (Keychain on iOS, Keystore on Android, secure browser storage)

Audit Logging and Firebase Integration

Firebase Realtime Database and Firestore will automatically log all database operations, including read, write, and delete operations, along with user identity, timestamp, and operation details. These comprehensive audit logs will be:

- Stored securely in Firebase to prevent tampering
- Monitored by security rules to ensure only authorized users access logs
- Regularly reviewed by administrators to identify suspicious patterns
- Exported and retained for compliance and forensic purposes
- Integrated with the notification system to alert administrators of critical security events

Together, these Firebase-based security technologies create a comprehensive, defense-in-depth security architecture that protects healthcare information from unauthorized access, maintains audit trails for regulatory compliance, and enables rapid detection and response to security incidents.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Data Storage and Database Technology

The system will utilize a modern cloud-based database platform such as Firebase or similar services as its primary data storage and management infrastructure. Cloud databases provide real-time data storage, automatic data synchronization, scalable infrastructure, and built-in security and backup capabilities.

Such platforms offer significant advantages for healthcare record management systems, including secure and encrypted cloud storage, horizontal and vertical scalability to accommodate growing data volumes, real-time data synchronization across components, automatic backup and disaster recovery capabilities, and comprehensive built-in security features and compliance support. Patient records, user information, appointment details, system logs, audit trails, and other healthcare-related data will be stored within the selected database infrastructure.

To enhance data protection and meet healthcare privacy requirements, sensitive information stored within the database will be secured through multiple layers of protection including authentication and authorization controls, database-level security rules, encryption-at-rest for stored data, encryption-in-transit for data transmission, and comprehensive audit logging of all data access and modifications. These features help maintain the fundamental security principles of confidentiality, integrity, and availability of healthcare records while ensuring that only authorized users can access specific data when needed for clinical operations.

The use of cloud database technologies reduces the need for complex on-premises server management and infrastructure maintenance, making it a practical, cost-effective, and

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

maintainable solution for small clinics with limited IT resources and technical staff.

Development Environment and Tools

The primary integrated development environment (IDE) for the project will be Visual Studio Code (VS Code), a comprehensive and widely adopted source-code editor that provides extensive features and tools for modern software development. Visual Studio Code is extensively used by professional development teams for its comprehensive feature set, strong community support, and continuous updates.

VS Code offers essential development features including syntax highlighting for multiple languages, integrated debugging tools and breakpoint management, intelligent code completion and IntelliSense, built-in version control integration with Git, extensive extension ecosystem, integrated terminal, and comprehensive support for various file types and technologies.

Its compatibility with HTML5, CSS3, JavaScript, and cloud database services makes it an ideal development platform for building the proposed healthcare record management system.

Furthermore, Visual Studio Code supports collaborative development, pair programming, project organization, and team-based version control, allowing multiple developers to work collaboratively and manage system components effectively throughout the development lifecycle.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Data Gathering

To determine the problem of the study we composed to do the following:

Interviews

Interviews will be conducted with key stakeholders directly involved in the daily operations and management of patient records within the participating clinics. Respondents will include clinic doctor or owners, nurses, and administrative or clinic staff who are responsible for encoding, filing, retrieving, and safeguarding patient information. A semi-structured interview format will be used, guided by a prepared set of open-ended questions but flexible enough to allow follow-up questions and clarification whenever new or unexpected information arises during the discussion.

Interview

The interview conducted with the key stakeholders directly involved the daily operations and management of their patient data records within involved clinics. The respondents include clinic doctor or owners, nurses, and clinic staff who are responsible for encoding, filling, retrieving, and protecting patient data records or information. A conversational interview format will be used, guided by a prepared set of questions but flexible enough to allow follow-up questions and clarification whenever new or unexpected information arises during the discussion.

The interview questions will focus on several key areas, including the clinic's current method of storing and managing

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

patient records whether paper-based, digital(spreadsheet), or both, the specific security measures currently in place such as passwords, or access restrictions, the staff's awareness and understanding of data privacy requirements under the Data Privacy Act of 2012, and the challenges, difficulties, or security incidents they have personally encountered or observed while handling patient information. Respondents will also be asked about their expectations, concerns, and preferences regarding a new digital system, which will help the researchers identify usability requirements and potential barriers to adoption.

With the consent of the respondents, interviews will be documented through written notes and, where permitted to ensure accuracy and completeness of the information gathered. The insights collected through this method will serve as a primary source of qualitative data for identifying functional requirements, security vulnerabilities, and user expectations, and will directly inform the threat modeling and system design phases of the study.

Observations

In addition to interviews, direct observation of the actual clinical workflows and record-handling practices within the participating clinic will be conducted. Observation is particularly valuable in this study because certain practices, habits, or shortcuts related to data security are often normalized by staff and may not be explicitly mentioned during interviews, yet they may represent significant security risks. Observing the environment firsthand allows the researchers to

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

see how patient records are actually created, accessed, stored, transferred, and disposed of during real clinical operations.

During the observation period, the research team will use a structured observation checklist to systematically document relevant details such as how patient information or digital records are physically or electronically stored, whether computers and workstations are left unattended or unlocked while logged in, whether individual staff members use their own login credentials or share a single common account, how visitors and non clinical personnel are able to access areas where records are kept, and how backup copies of records, if any, are created and stored. The researchers will also observe the general patient registration and consultation process from beginning to end to understand how patient data flows through the clinic and at which points it may be exposed to risk.

Observations will be conducted with the full knowledge and permission of clinic management to ensure ethical compliance and to avoid disrupting normal clinic operations. The findings from this method will be compared against the information gathered from interviews in order to validate, supplement, or clarify the data collected, and will help the researchers identify the concrete, real world vulnerabilities that need to be addressed by the multi-layered defense architecture of the proposed system.

Review of Existing Clinical Health Records

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

The third data gathering method involves a thorough review of the clinic's existing clinical health records, whether these are maintained in physical paper form, basic digital formats such as spreadsheets. This method allows the researchers to examine the actual structure, content, and format of the information that clinic staff currently collect and maintain for each patient, without relying solely on the recollection or description of the respondents.

Specifically, the review will focus on identifying the standard data fields currently used to record patient information, such as personal identifiers, medical history, diagnoses, prescriptions, laboratory results, and consultation notes, so that these can be properly translated into a well-structured and secure database schema for the proposed system. The researchers will also examine whatever existing security or access-control measures, if any, are already applied to these records, including whether records are kept in locked cabinets, whether digital files are password-protected, and whether any form of access logging or record of who accessed a given file currently exists.

This review process serves two important purposes for the study. First, it provides a factual and detailed basis for designing the data model and record-keeping features of the proposed system, ensuring that no essential clinical information is lost or overlooked during the transition from the clinic's current record-keeping method to the new digital platform. Second, it enables the researchers to perform a clear gap analysis between the security measures currently applied to existing records and the security requirements that the proposed multi-layered

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

defense system must ultimately fulfill, this gives us a solid reason for adding each layer of security to the system.

Comprehensive Testing and Quality Assurance Procedures

To ensure that the proposed Secure Healthcare Record Management System functions correctly, meets all specified user requirements, maintains data security, and provides adequate protection for sensitive healthcare information, a comprehensive series of testing procedures will be systematically conducted throughout all phases of the development process. Testing represents a critical and essential phase in healthcare software development because it helps identify defects and vulnerabilities, verify that system functionality meets specifications, evaluate system performance under realistic conditions, and assess the effectiveness of implemented security features and controls.

The proposed system will undergo multiple comprehensive testing phases including: (1) Unit Testing, (2) Integration Testing, (3) System Testing, and (4) User Acceptance Testing (UAT). These sequential and overlapping testing procedures will help ensure that the system is reliable, secure, performs efficiently, and is suitable for safe deployment and operation within a small clinical environment.

Unit Testing

Unit Testing represents the initial and lowest level of testing conducted during the development phase. This process focuses on examining and testing individual components, modules, or functions of the system to verify that each unit performs

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

according to its intended design specifications and behaves correctly in isolation.

During this stage, developers will systematically test specific system functionalities independently, including:

- User registration processes and account creation workflows
- User login mechanisms and authentication validation
- Patient information entry, storage, and retrieval operations
- Record updating and deletion functions with proper validation
- Notification and alert feature functionality
- Database connectivity and data storage operations
- Access control mechanisms and user permission enforcement
- Data encryption and security functions
- Session management and timeout functionality
- Error handling and exception management

The primary objective of Unit Testing is to identify coding errors, logic flaws, algorithmic defects, and functional issues at the earliest possible stage of development. By testing individual modules and functions separately and in isolation, developers can quickly detect and resolve issues before integrating them into the complete and larger system. Successful completion of comprehensive Unit Testing helps improve overall system stability, reduces the likelihood of cascading errors during later testing phases, and ensures the quality of foundational code components.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Integration Testing

Following successful completion of Unit Testing for individual components, Integration Testing will be conducted to verify that different modules and components work together correctly when combined. This phase ensures that data flows properly between components, that component interfaces are correctly implemented, and that integrated functionality operates as designed.

Integration Testing will assess:

- Communication between frontend and backend components
- Database connectivity and data transaction processing
- API functionality and data exchange
- Security control integration across components
- Data consistency across integrated modules

System Testing

After successful completion of Integration Testing, the entire healthcare record management system will undergo comprehensive System Testing. This phase evaluates the fully integrated system as a complete, functional whole to determine whether all modules work together correctly, efficiently, and reliably.

System Testing will assess comprehensive aspects of the proposed system, including:

- Overall system functionality against specifications
- Integration between frontend user interface and backend processing components
- Database performance and data consistency under operational loads

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- User authentication and authorization mechanisms across the system
- Security controls and access restrictions effectiveness
- Data encryption and protection measures
- System responsiveness and reliability under normal and peak usage
- Error handling and system recovery mechanisms
- System stability under extended operation

Rigorous security-related tests will be conducted during this stage to determine whether the system can effectively prevent unauthorized access, detect security violations, and protect sensitive patient records from compromise. The research team will verify that users can only access information according to their assigned roles and permissions, that data is properly encrypted, that audit logs accurately record activities, and that the system maintains data integrity. Additionally, testing will ensure that data is properly stored, transmitted securely, and protected within the system and that the system can recover from failures.

The goal of System Testing is to validate comprehensively that the healthcare record management system meets all specified functional and security requirements, operates reliably under realistic usage conditions, and achieves the intended security objectives.

User Acceptance Testing (UAT)

User Acceptance Testing (UAT) represents the final and critical testing phase before the system is considered ready for deployment and operational use. This stage involves evaluating

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

the system from the perspective of its intended users and stakeholders, such as clinic administrators, healthcare practitioners, nursing staff, medical technicians, and other authorized personnel.

During UAT, carefully selected representative users will interact with the system and perform actual tasks that closely reflect and simulate real-world clinical operations and workflows. These activities will include:

- Patient registration and demographic data entry
- Creation and management of comprehensive electronic health records
- Updating and modification of patient information
- Searching for and retrieving patient records efficiently
- Managing user accounts and permissions
- Viewing notifications, alerts, and system reports
- Accessing records based on assigned roles and permissions
- Performing typical clinical workflows and operations

Participants will critically assess and provide detailed feedback regarding whether the system is intuitive and easy to use, operationally efficient, secure and trustworthy, and capable of effectively supporting their daily healthcare management activities and clinical workflows. Comprehensive feedback will be systematically collected regarding system functionality, user interface design quality, navigation intuitiveness, system performance and responsiveness, security features, and overall user satisfaction and acceptance.

Any issues, recommendations, improvement suggestions, or technical concerns identified during User Acceptance Testing

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

will be reviewed in detail and systematically addressed before the final implementation of the system in the clinical environment. The results of UAT will help determine definitively whether the proposed healthcare record management system successfully meets the needs, expectations, and requirements of its intended users and stakeholders.

Evaluation and Assessment Criteria

The proposed Secure Healthcare Record Management System will be comprehensively evaluated using multiple criteria to determine its overall effectiveness in meeting the stated objectives of the study and addressing the security challenges and operational needs faced by small clinics. The evaluation process will systematically assess various critical aspects of the system, including its functionality, usability, security posture, operational efficiency, performance characteristics, reliability, and its demonstrated ability to uphold and maintain the fundamental principles of Confidentiality, Integrity, and Availability (CIA).

These comprehensive evaluation criteria will provide a thorough, multi-dimensional measure of the system's overall quality, security effectiveness, operational reliability, and suitability for healthcare environments and clinical applications.

Functional Completeness and Correctness

Functionality refers to the extent to which the proposed system accurately performs its intended tasks and comprehensively fulfills all specified functional requirements. This criterion evaluates whether all system features operate correctly,

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

reliably, and support the healthcare record management needs and clinical workflows of the clinic.

The functionality assessment will focus on features and capabilities including:

- Accurate patient registration and comprehensive record management
- Secure user authentication and account management functionality
- Proper implementation of role-based access control mechanisms
- Effective appointment scheduling and information management
- Reliable data storage and retrieval operations
- Notification and alert feature functionality
- Comprehensive report generation and record update capabilities
- System administration and maintenance functions

A highly functional system should accurately and reliably execute all required processes while minimizing errors, maintaining data integrity, and ensuring smooth operation of critical healthcare-related activities.

Usability and User Experience

Usability measures how easy, convenient, and intuitive the system is for users to learn, understand, and operate effectively. Since healthcare personnel may possess varying levels of technical expertise and computer skills, the system should provide an intuitive, accessible, and user-friendly

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

interface that supports efficient and error-free task completion.

The usability evaluation will examine:

- Ease of navigation through system menus and features
- Quality and effectiveness of user interface design
- Clarity of instructions, prompts, and system feedback
- Accessibility of system features for users with varying abilities
- Learning curve and required training time for new users
- Overall user satisfaction and acceptance

A system with high usability enables healthcare staff to perform their clinical and administrative responsibilities efficiently and effectively without requiring extensive technical training or support.

Security Posture and Threat Protection

Security represents one of the most critical evaluation criteria of this study because the system is specifically designed to protect sensitive healthcare information and maintain patient privacy. This criterion comprehensively assesses the effectiveness of the implemented security mechanisms and controls in preventing unauthorized access, detecting security violations, mitigating data breaches, and defending against emerging cyber threats.

The security evaluation will focus on:

- Effectiveness of authentication mechanisms and credential validation
- Robustness of access control policies and enforcement

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Strength of data encryption methods and key management
- Protection against unauthorized access and intrusion attempts
- User activity monitoring and anomaly detection capabilities
- Comprehensive audit logging and forensic capabilities
- Security of stored data (encryption-at-rest) and transmitted data (encryption-in-transit)
- Vulnerability to known attack vectors and exploitation techniques
- Recovery procedures and incident response capabilities

The system should demonstrate strong, proven protection against potential internal and external threats while ensuring that only properly authenticated and authorized personnel can access confidential patient information.

Operational Efficiency

Efficiency refers to the system's ability to perform clinical and administrative tasks using minimal computational resources while maintaining optimal functionality and reliability. An efficient system reduces processing delays, minimizes workload on staff, and improves overall operational productivity and workflow efficiency within the clinic.

The efficiency assessment will comprehensively include:

- Speed of patient record retrieval operations
- Data processing time for transactions
- Resource utilization and system load optimization
- Workflow improvement and process streamlining
- Reduction of manual processes and administrative burden

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- System responsiveness and responsiveness during routine operations
- Scalability to accommodate growing data volumes

A highly efficient system contributes to faster service delivery, reduced staff workload, and improved healthcare management processes and patient care quality.

System Performance Characteristics

Performance evaluates how effectively the system operates under different conditions, varying workloads, and real-world usage patterns. This criterion measures the system's responsiveness, processing speed, and capability to handle multiple simultaneous operations and users without significant delays or degradation of service quality.

The performance evaluation will consider:

- Response time for user interactions and queries
- System processing speed for complex operations
- Database transaction performance under load
- Simultaneous user handling and concurrent session management
- Stability under continuous operation and peak usage
- Loading times for pages and data retrieval
- Memory management and resource optimization

A well-performing system should maintain consistent, reliable operation and responsiveness even during periods of increased usage and peak demand.

System Reliability and Availability

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Reliability refers to the system's demonstrated ability to consistently perform its intended functions without failure, errors, or unexpected behavior over a specified operational period. Healthcare information systems must remain highly dependable and available because interruptions, errors, or failures can directly and negatively affect patient care quality and clinical operations.

The reliability assessment will focus on:

- System stability and uptime metrics
- Error-free operation and exception handling
- Recovery capabilities from system failures
- Data consistency and integrity maintenance
- Comprehensive backup and restoration capabilities
- Availability and accessibility of services during operation
- Mean time to failure (MTBF) and mean time to repair (MTTR) metrics

A reliable healthcare record management system ensures continuous access to critical patient information, minimizes the risk of service disruption, and maintains data integrity and consistency.

Information Security Principles: Confidentiality, Integrity, and Availability (CIA)

The Confidentiality, Integrity, and Availability (CIA) model serves as the fundamental and central framework for evaluating information security and privacy protection within the proposed system. Since the study's primary objective involves developing a secure healthcare record management system, special emphasis

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

will be placed on comprehensively assessing these three critical security principles.

Confidentiality

Confidentiality ensures that sensitive patient information and healthcare data is accessible exclusively to properly authenticated and authorized individuals with legitimate need-to-know. This criterion evaluates the effectiveness of security measures and controls designed to prevent unauthorized viewing, disclosure, unauthorized modification, and misuse of healthcare records.

Indicators of confidentiality include:

- Secure and robust user authentication mechanisms
- Effective role-based access restrictions and enforcement
- Comprehensive data encryption for stored and transmitted data
- Protection against unauthorized access and intrusion attempts
- Strong privacy controls and patient information protection
- Secure credential management and password policies

Integrity

Integrity ensures that healthcare records and patient data remain accurate, complete, and faithfully represent the actual clinical information. This criterion assesses whether data can be altered only by properly authorized users and whether comprehensive mechanisms exist to detect and prevent unauthorized changes or data corruption.

Indicators of integrity include:

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- Accuracy and completeness of stored records
- Protection against unauthorized modification and tampering
- Comprehensive data validation processes and checksums
- Detailed audit trails and comprehensive activity logs
- Consistency of information across the system
- Prevention of data corruption and loss

Availability

Availability ensures that properly authenticated and authorized users can reliably access required healthcare information whenever it is needed for clinical operations, patient care, and healthcare management. This criterion evaluates the system's ability to provide continuous, uninterrupted access to data and services.

Indicators of availability include:

- High system uptime and reliability metrics
- Rapid accessibility of patient records
- Comprehensive backup and recovery mechanisms
- Protection against system failures and outages
- Demonstrated ability to recover from disruptions
- Redundancy and failover capabilities

Maintaining confidentiality, integrity, and availability is essential and fundamental for protecting patient information, ensuring regulatory compliance, supporting clinical decision-making, and ensuring the overall effectiveness of healthcare record management and patient care delivery.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

Supporting Diagram

Data Flow Diagram & Entity Relationship

1. System Overview

PureEHC is a browser-based clinic management system for a single-clinic (solo practice) deployment. It is implemented as a static front end (index.html + app.js, vanilla JavaScript) authenticating through Firebase Authentication (Google Sign-In) and persisting all clinical, administrative, and audit data in Cloud Firestore. There is no backend server or Cloud Functions layer – all business logic, validation, ID generation, and role enforcement run client-side in app.js, backed by Firestore Security Rules.

Three staff roles are recognized by the application: owner, nurse, and receptionist. The owner role has exclusive access to Staff Management and Clinic/Doctor Settings; nurse and owner are treated as "clinical" roles for patient-record and prescription purposes.

The diagrams and tables below reflect exactly what is implemented today: eight Firestore data stores (users, staffInvites, patients, patients/{id}/visits, prescriptions, appointments, clinicSettings, auditLogs), ten functional processes, and the data relationships that connect them.

2. Data Flow Diagram(DFD)

2.1 Context Diagram- Level 0

The context diagram treats PureEHC as a single process and shows its boundary with the outside world: the clinic staff who

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

operate it, the Firebase Authentication service that verifies identity, and the Cloud Firestore database that stores all persistent data.

PureEHC — Context Diagram (DFD Level 0)

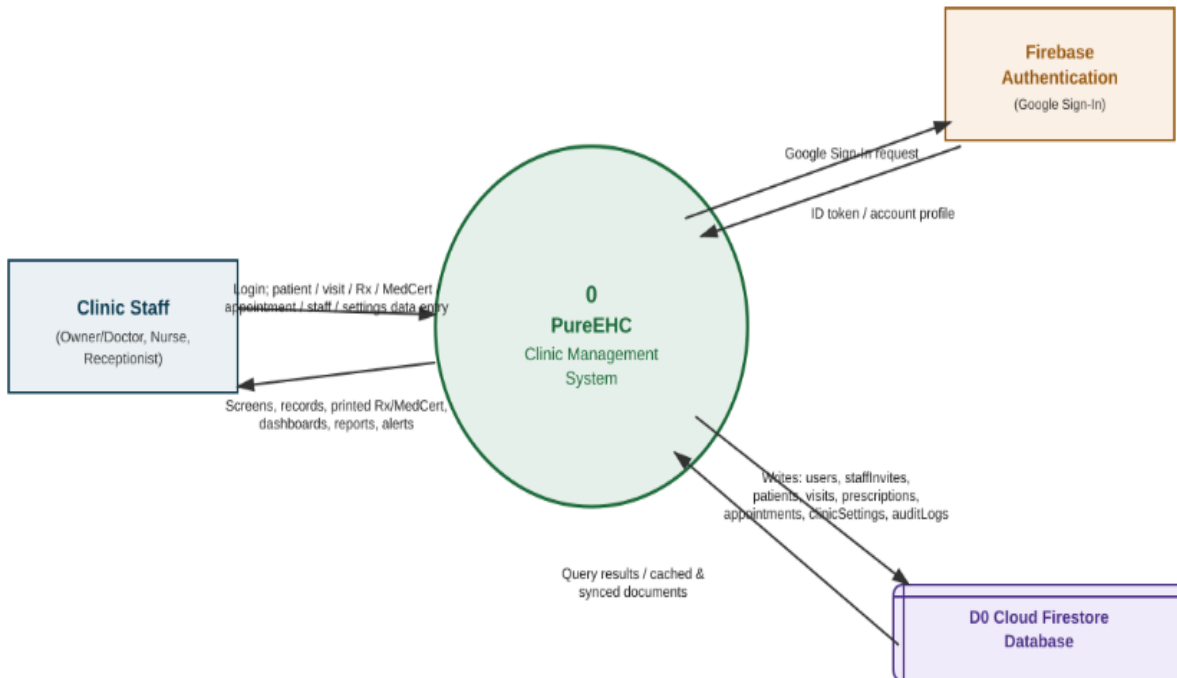


Figure 1. DFD context diagram (Level 0)

Element	Type	Description
Clinic Staff	External Entity	Owner/Doctor, Nurse, and Receptionist accounts that sign in and operate every screen of the system.
Firebase Authentication	External Entity	Google Identity Platform service used exclusively for Google

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		Sign-In; issues the identity token consumed by the app.
0 – PureEHC Clinic Management System	Process	The entire client application (app.js/index.html) that mediates all interaction between staff and the database.
D0 – Cloud Firestore Database	Data Store	The single NoSQL backend holds all eight collections described in Section 2.3.

2.2 Level 1 Data Flow Diagram

The Level 1 diagram decomposes Process 0 into the ten functional processes implemented in app.js, and shows exactly which Firestore collection(s) each process reads from or writes to.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

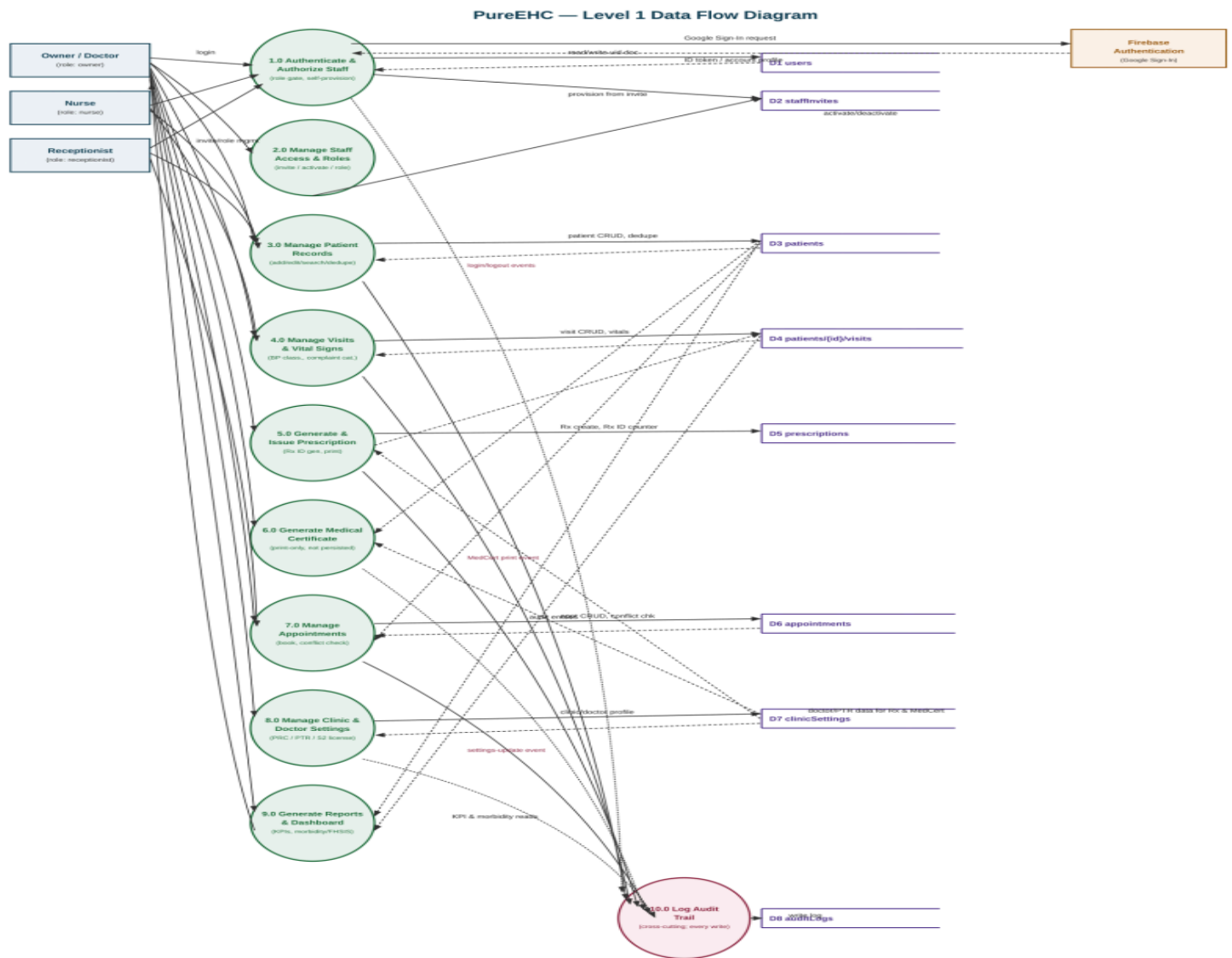


Figure 2. DFD Level 1- Process Decomposition

2.3 Process Description

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

#	Process	Description	Reads	Writes
1.0	Authenticate & Authorize Staff	Handles Google Sign-In via Firebase Auth, looks up the caller's users/{uid} document, and self-provisions a new user record the first time a staffInvites/{email} entry is found active. Login, manual logout, and 15-minute session-timeout auto-logout are all recorded to the audit trail.	users, staff Invites	users (on first login), auditLogs
2.0	Manage Staff Access & Roles	Owner-only screen to invite staff by email, assign role (owner/nurse/receptionist), and activate/deactivate accounts. Confirmed: this process does not call the audit-logging function anywhere in app.js – staff/role changes leave no entry	staffInvites, users	staffInvites, users

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		in auditLogs (see Section 5.2 finding).		
3.0	Manage Patient Records	Two-step Add/Edit Patient form; duplicate-name/DOB/address detection; soft delete; patient list search, sort and pagination; generates the patientCode (PAT-YYYY-NNNN).	patients	patients, auditLogs
4.0	Manage Visits & Vital Signs	Owner and Nurse only (isClinical()), enforced by Firestore rule on the visits subcollection. Adds a visit under a patient's visits subcollection with vitals (BP with AHA auto-classification, RR, CR, temperature, O2 sat), SOAP-style notes, chief-complaint category, and per-visit consultation fee.	patients, patients/{id}/visits	patients/{id}/visits, auditLogs

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

5.0	Generate & Issue Prescription (Rx)	Owner-only. Builds structured medication lines, generates a sequential Rx ID (RX-YYYY-NNNNNN) scoped by year, saves the prescription record, links it back to the triggering visit (rxId), and renders the printable PH-format Rx. Gated by isOwner() in app.js AND by the Firestore rule allow create: if isOwner() on /prescriptions/{rxId} – enforced at both the UI and database layers.	patients, prescriptions, clinicSettings,	prescriptions, patients/{id}/visits, auditLogs
6.0	Generate Medical Certificate (MedCert)	Owner-only by UI convention (button lives inside a role-owner-only container). Produces a printable PH-format Medical Certificate from patient and doctor/clinic data.	patients, clinicSettings	auditLogs (print event only; no MedCert document is stored)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		Not persisted as its own Firestore record – generated on demand at print time, and logged to auditLogs. Note: unlike Rx, the underlying <code>openMedCertModal()/printMedCert()</code> functions carry no <code>isOwner()</code> check of their own, and there is no Firestore rule to fall back on since no document is written – see Section 5.2.		
7.0	Manage Appointments	Books, edits, and soft-deletes appointments; checks for date/time double-booking before saving; renders list and calendar views.	appointment s, patients	appointments, auditLogs
8.0	Manage Clinic & Doctor Settings	Owner-only screen storing doctor/clinic identity and PRC/PTR/S2 license data used across Rx and MedCert printing,	clinicSetti ngs	clinicSettings, auditLogs

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		including PTR-expiry warnings. Every save is recorded to the audit trail ('Clinic settings updated').		
9.0	Generate Reports & Dashboard	"Today's Clinic Activity" KPI cards (total active patients, cash collected today) and the DOH-FHSIS-aligned Morbidity Report, both built with a collectionGroup query across every patient's visits subcollection.	patients, patients/*/visits (collection Group)	– (read-only)
10.0	Log Audit Trail	Cross-cutting process invoked from Processes 1.0, 3.0, 4.0, 5.0, 6.0, 7.0, and 8.0 (confirmed against every logAudit() call site in app.js). Notably NOT invoked by 2.0 Manage Staff Access – staff invite/role/activation changes are not audited, a gap worth	–	auditLogs

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		flagging. 9.0 Reports is read-only and correctly has no audit writes.		
--	--	---	--	--

2.4 Data Stores

ID	Collection	Purpose	Document Key
D1	users	One document per authenticated staff account.	uid (Firebase Auth UID)
D2	staffInvites	Pending/active invitations used to self-provision a user's document on first sign-in.	email (lowercase)
D3	patients	Master patient profile records.	auto-generated document ID
D4	patients/{patientId}/visits	Subcollection of clinical encounters per patient (vitals, SOAP notes, medications, fee).	auto-generated document ID
D5	prescriptions	Issued prescriptions, keyed by the human-readable Rx number so it doubles as the printable Rx ID.	rxId (e.g. RX-2026-000001)
D6	appointments	Scheduled appointments, walk-in or tied to an existing patient.	auto-generated document ID

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

D7	clinicSettings	Singleton document holding clinic/doctor identity and license numbers.	fixed ID: doctorProfile
D8	auditLogs	Append-only trail of add/edit/delete/login actions. Any active staff member can write an entry; only the owner can read the trail (Firestore rule).	auto-generated document ID

3. Entity Relationship Diagram (ERD)

Firestore is a schemaless document database with no engine-enforced foreign keys; the entities, keys, and relationships below are the ones the application (app.js) actually reads and writes, and are therefore "soft" relationships enforced entirely in client code and Firestore Security Rules rather than by the database engine.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

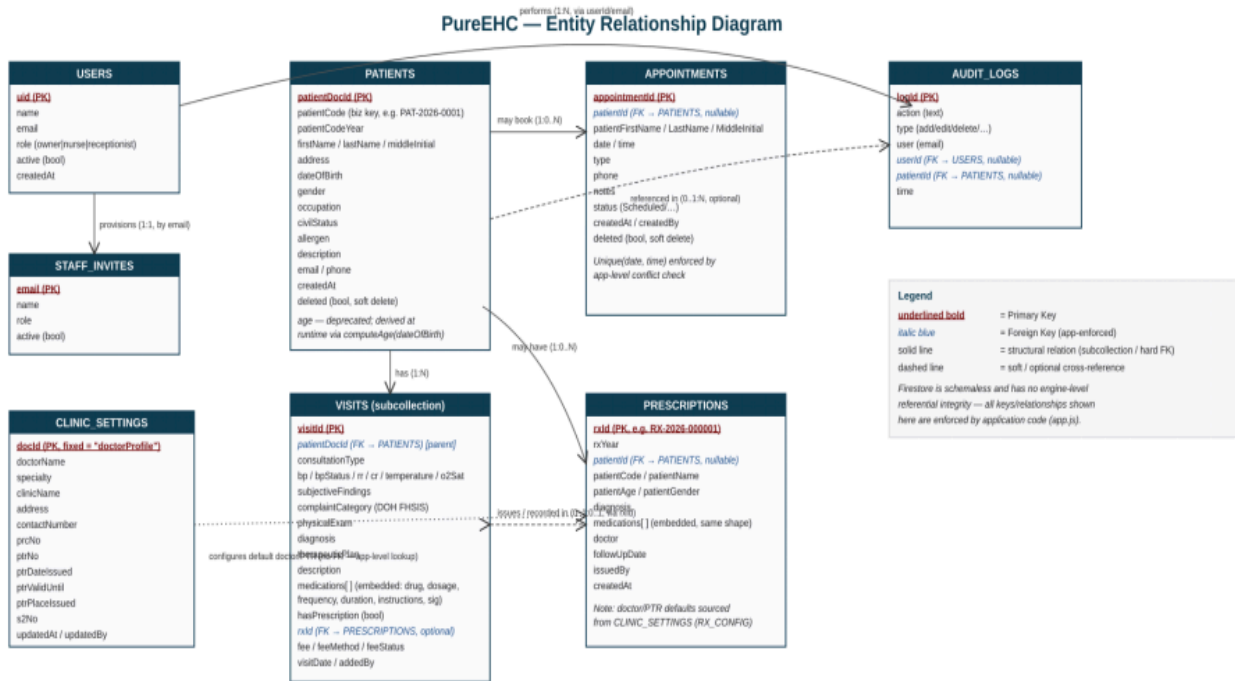


Figure 3. Entity Relationship

3.1 Entity Attribute Reference

USERS (PK: uid)

Attribute	Type	Notes
uid	string	Primary key — Firebase Authentication UID.
name	string	Display name, taken from the staff invite or Google profile.
email	string	
role	string	One of: owner, nurse, receptionist.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

active	boolean	Gates login; deactivation blocks access without deleting the account.
createdAt	timestamp	Set on self-provisioning.

STAFF_INVITES (PK: email)

Attribute	Type	Notes
email	string	Primary key (lowercase) – matched against the signed-in Google account email.
name	string	
role	string	Role to assign once the invite is consumed.
active	boolean	Must be true for self-provisioning to succeed.

PATIENTS (PK: patientDocId)

Attribute	Type	Notes
patientDocId	string	Primary key – Firestore auto-generated document ID.
patientCode / patientCodeYear	string / number	Business key, e.g. PAT-2026-0001; assigned on first prescription issuance.
firstName, lastName, middleInitial	string	

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

address	string	Used together with dateOfBirth for duplicate-patient detection.
dateOfBirth	string (date)	Source of truth for age; age is computed at runtime via computeAge(), not stored (the legacy stored age field is explicitly cleared with deleteField()).
gender, occupation, civilStatus	string	
allergen	string	Printed as a safety warning on Rx/MedCert.
description	string	Free-text notes.
email, phone	string	
createdAt	timestamp	
deleted	boolean	Soft delete flag; deleted patients are filtered out of active queries.

VISITS (PK: visitId – subcollection of PATIENTS)

Attribute	Type	Notes
visitId	string	Primary key – Firestore auto-generated document ID.
patientDocId	string (FK)	Implicit foreign key – the parent PATIENTS document (structural, via subcollection path).
consultationType	string	

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

bp, bpStatus	string	Blood pressure reading and its AHA auto-classification.
rr, cr, temperature, o2Sat	string	Respiratory rate, cardiac rate, temperature, O2 saturation.
subjectiveFindings, physicalExam, diagnosis, therapeuticPlan, description	string	SOAP-style clinical notes.
complaintCategory	string	Chief-complaint category aligned to DOH FHSIS, feeds the Morbidity Report.
medications	array<object>	Embedded structured Rx lines: num, drug, dosage, frequency, duration, instructions, sig.
hasPrescription	boolean	true when medications is non-empty.
rxId	string (FK, nullable)	References PRESCRIPTIONS.rxId when this visit produced/received a prescription.
fee, feeMethod, feeStatus	number / string / string	Per-visit consultation fee; feeds the "Cash Today" KPI.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

visitDate, addedBy	timesta mp / string	
-----------------------	---------------------------	--

PRESCRIPTIONS (PK: rxId)

Attribute	Type	Notes
rxId	string	Primary key and document ID, e.g. RX-2026-000001 (sequential, scoped by rxYear) .
rxYear	number	Used to scope the sequential counter.
patientId	string (FK, nullabl e)	References PATIENTS.patientDocId; nullable to allow a walk-in Rx issued without a saved patient profile.
patientCode, patientName, patientAge, patientGender	string	Denormalized snapshot of the patient at time of issuance.
diagnosis	string	
medications	array<o bject>	Same embedded shape as VISITS.medications.
doctor	string	Defaults from clinicSettings/doctorProfile (RX_CONFIG.doctorName) if not overridden.
followUpDate	string (date,	

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

	nullable)	
issuedBy	string	Email of the staff member who issued it.
createdAt	timestamp	

APPOINTMENTS (PK: `appointmentId`)

Attribute	Type	Notes
<code>appointmentId</code>	string	Primary key – Firestore auto-generated document ID.
<code>patientId</code>	string (FK, nullable)	References <code>PATIENTS.patientDocId</code> ; nullable for a walk-in appointment booked before a patient profile exists.
<code>patientFirstName</code> , <code>patientLastName</code> , <code>patientMiddleInitial</code>	string	Captured directly on the appointment (denormalized, independent of the <code>PATIENTS</code> record).
<code>date</code> , <code>time</code>	string	Together checked for double-booking before insert.
<code>type</code> , <code>phone</code> , <code>notes</code>	string	
<code>status</code>	string	e.g. Scheduled.
<code>createdAt</code> , <code>createdBy</code>	timestamp / string	
<code>deleted</code>	boolean	Soft delete flag.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

CLINIC_SETTINGS (PK: fixed document ID "doctorProfile")

Attribute	Type	Notes
docId	string	Fixed primary key: doctorProfile (singleton document).
doctorName, specialty	string	
clinicName, address, contactNumber	string	
prcNo, ptrNo, ptrPlaceIssued	string	Professional license numbers printed on Rx/MedCert.
ptrDateIssued, ptrValidUntil	string (date)	Drives the PTR-expiry warning banner.
s2No	string	S2 license for controlled-substance prescribing.
updatedAt, updatedBy	timestamp / string	

AUDIT_LOGS (PK: logId)

Attribute	Type	Notes
logId	string	Primary key – Firestore auto-generated document ID.
action	string	Human-readable description of the event.
type	string	e.g. add, edit, delete.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

<code>user, userId</code>	<code>string</code>	<code>userId (FK, nullable) references USERS.uid; user stores the email for quick display.</code>
<code>patientId</code>	<code>string (FK, nullable)</code>	<code>References PATIENTS.patientDocId when the action concerned a specific patient.</code>
<code>time</code>	<code>timestamp</code>	

3.2 Relationship Summary

Relationship	Cardinality	Enforcement
STAFF_INVITES → USERS	1 : 1 (by email, on first sign-in)	App logic in the auth-state listener; not a stored FK.
PATIENTS → VISITS	1 : N	Structural – VISITS is a Firestore subcollection of PATIENTS.
PATIENTS → PRESCRIPTIONS	1 : 0..N (optional)	App-level FK: PRESCRIPTIONS.patientId; null allowed for walk-in Rx.
PATIENTS → APPOINTMENTS	1 : 0..N (optional)	App-level FK: APPOINTMENTS.patientId; null allowed for walk-in booking.
VISITS ↔ PRESCRIPTIONS	0..1 : 0..1	Cross-reference via VISITS.rxId; PRESCRIPTIONS does not store a reciprocal visitId.
USERS → AUDIT_LOGS	1 : N	App-level FK: AUDIT_LOGS.userId / user. Write allowed for any active

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

		staff member; read restricted to owner only by Firestore rule.
PATIENTS → AUDIT_LOGS	0..1 : N (optional)	App-level FK: AUDIT_LOGS.patientId; null for non-patient actions (e.g. staff or settings changes).
CLINIC_SETTINGS → PRESCRIPTIONS / MEDCERT	1 : N (configuration reference)	Read at print/issue time via the in-memory RX_CONFIG cache; not a stored key relationship.

5. Security Enforcement – Firestore RBAC Matrix

This section maps every collection to its actual Firestore Security Rule, cross-referenced against the role checks already present in app.js. Three roles exist: owner, nurse, receptionist. `isActiveStaff() = signed in AND users/{uid}.active == true`. `isClinical() = isActiveStaff() AND role in [owner, nurse]`. `isOwner() = isActiveStaff() AND role == owner`.

Collection	Read	Create	Update	Delete
<code>users/{userId}</code>	Self, or Owner	Self only, and only if it matches an active staffInvites entry with the same role	Owner only; limited to role, active, name fields	Never (false)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

staffInvites/{email}	Owner, or the invited person themselves	Owner only	Owner only	Owner only
patients/{patientId}	Any active staff	Any active staff	Any active staff (non-owners cannot flip the deleted flag)	Never (false – soft delete only)
patients/{id}/visits/{visitId}	Clinical only (owner/nurse)	Clinical only	Clinical only	Never (false)
appointments/{apptId}	Any active staff	Any active staff	Any active staff	Never (false – status/deleted flag used instead)
prescriptions/{rxId}	Clinical only (owner/nurse)	Owner only	Never (false – prescriptions are immutable once issued)	Never (false)

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

<code>auditLogs/{logId}</code>	Owner only	Any active staff	Never (false)	Never (false)
<code>clinicSettings/{settingId}</code>	Any active staff	Owner only (write)	Owner only (write)	Owner only (write)
Everything else	Denied	Denied	Denied	Denied (default-deny catch-all)

5.1 Notable design strengths

- Default-deny catch-all (`match /{document=**} { allow read, write: if false; }`) closes off any collection not explicitly listed – a solid baseline security posture.
- Prescriptions are effectively immutable once created (`update/delete both false`), which matches the medico-legal expectation that a dispensed Rx record shouldn't be editable after the fact.
- Rx issuance is defended in depth: the UI hides the print controls from non-owners (`isOwner()` check in `app.js`) AND the Firestore rule independently requires `isOwner()` to create a prescriptions document. Either layer alone would stop a non-owner; having both means a client-side bug or console tampering still fails at the database.
- User self-provisioning is tightly scoped: a new `users/{uid}` document can only be created by the user themselves, and only with a role that matches an active, pending `staffInvites` entry for their email – someone

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

can't self-assign the owner role by simply calling the client SDK.

- Audit log visibility is itself access-controlled: any active staff member can write an audit entry (so nothing is silently dropped), but only the owner can read the trail back – preventing staff from reviewing or inferring each other's activity.

5.2 Findings worth raising proactively at defense

- Staff/role changes are not audited. Process 2.0 (Manage Staff Access & Roles) never calls `logAudit()`, so inviting, promoting, or deactivating a staff member leaves no entry in `auditLogs` – the one administrative action with the highest security impact is currently the one action with no audit trail.
- Medical Certificate access relies on UI hiding only, not a function-level or database-level check. The `MedCert` button is wrapped in a role-owner-only CSS class, but `openMedCertModal()` and `printMedCert()` perform no `isOwner()` check themselves, and because a `MedCert` is never written to `Firestore`, there is no `Security Rule` to fall back on either. This differs from the `Rx` flow, which checks `isOwner()` inside the function in addition to hiding the button. Practically, a non-owner cannot reach the feature through the normal UI, but nothing stops a direct function call (e.g. via the browser console) from generating and printing one.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

6. Assumptions & Notes

- All diagrams and attribute lists were derived directly from the Firestore calls (`collection()`, `doc()`, `addDoc()`, `setDoc()`, `updateDoc()`) and form-field bindings present in `app.js` and `index.html` – no entities or flows were invented.
- Firestore has no native referential-integrity engine; every "foreign key" described above is a plain string field that the application treats as a reference. Nothing prevents an orphaned reference at the database level – integrity depends entirely on `app.js` and Firestore Security Rules.
- The Medical Certificate (MedCert) is intentionally not a data store: it is generated and printed on demand from `PATIENTS + CLINIC_SETTINGS` data and leaves no separate persisted document (confirmed by the absence of any `doc()/collection()` write referencing "medcert" in `app.js`).
- The legacy age field on `PATIENTS` is being phased out in favor of a computed value (`computeAge(dateOfBirth)`); existing documents are actively migrated by clearing the field with `deleteField()` whenever a patient record is edited.

PHINMA UNIVERSITY OF ILOILO

College of Information Technology Education

- The Reports/Dashboard process (9.0) uses a Firestore collectionGroup query across every patient's visits subcollection, which is why it is drawn reading from D4 directly rather than through Process 4.0.
- Role names (owner, nurse, receptionist) and the isClinical()/isOwner() gating shown throughout this document reflect the ROLES constant and helper functions defined at the top of app.js, cross-checked against and confirmed by the actual firestore.rules file (Section 5). Every role claim in Sections 2-5 is therefore backed by both the client code and the database-level rule, not by client code alone.